DIGITAL EGYPT PIONEERS INITIATIVE (DEPI) — SOFTWARE TESTING TRACK

BANKING TRANSACTION SYSTEM (BTS)

Milestone 3 Master Specification — System Analysis, UML & Database Design, Layered Architecture, REST API, UI/UX Prototype, Integration, Master Test Plan, RTM & UAT

Project Key: BTS | Team: Biscuit Bank Team | Architecture: Java 21 LTS, Spring Boot 3.5, Thymeleaf & SQLite (WAL Mode) | Date: October 2026

Project Team & Milestone 3 Module Ownership

Team Member	Role & Track Specialization	Milestone 3 Deliverable Module(s)	Jira Epic / Task Scope
Muhammad Sayyid	Software & Application Security Engineer (Architecture & API Lead)	Part 3 — System Architecture, Security Pipeline, Component & DFD (Level 0/1) Diagrams, RESTful API Specification & Error Contract	EPIC-1, ARCH-01..03, SEC-01..11, DOM-01, API-01..09
Aghapy Antonious	System Analyst & Behavioral UML Modeling Lead	Part 1 — Problem Statement, Project Objectives, Use Case, Sequence & Activity Diagrams, and System Design Interfaces (SDI)	US-01..25 Behavioral Flows, SDI Contracts
Aladdin Ahmed	Database Architect & Domain Modeling Lead	Part 2 — SQLite WAL Database Schema, Physical Data Dictionary, Entity-Relationship Diagram (ERD), Class & State Machine Diagrams	DATA-01..04, DOM-01..04, BR-01..29
Asmaa Mohamed	UI/UX Designer & Frontend Prototyping Lead	Part 4 — Interactive Google Stitch UI/UX Prototype, Customer Portal, Admin Console, Interactive Modals & 404 Security View	UI-01, UI-02, NFR-06, NFR-07, NFR-12
Somia Rashad	QA & Test Automation Lead (Integration, Test Plan & UAT)	Part 5 — System Integration Architecture, Master Test Plan, 69 Requirement-Based Test Cases, Bidirectional RTM & 14 UAT Scenarios	QA-01..04, SEC-TASK-02, DOM-05, IT-01..13, UAT S1..S14

Master Table of Contents & Document Structure

Part / Section	Title & Engineering Deliverable Scope	Traceability Coverage
Part 1 (§1.1 – §1.6)	System Analysis, Problem Statement, Objectives, Use Case, Sequence, Activity Diagrams & SDI	US-01 to US-25, BR-01 to BR-29, NFR-08
Part 2 (§2.1 – §2.3)	Database Design, SQLite WAL Schema Dictionary, ERD, OOP Class Diagram & Account Lifecycle State Machine	NFR-01, NFR-03, NFR-04, ACC-01..07, BR-07..23
Part 3 (§3.1 – §3.5)	System Architecture, Technology Stack, Component Diagram, DFD (Level 0 & Level 1), REST API & Error Contract	ARCH-01..03, SEC-01..11, AUTH, CUS, ACC, TXN, STM, ADM
Part 4 (§4.1 – §4.3)	UI/UX Prototype & Interactive Wireframes (Google Stitch Link + 22 Customer, Modal, 404 & Admin Screens)	UI-01, UI-02, NFR-05, NFR-06, NFR-07, NFR-12, US-01..25
Part 5 (§5.1 – §5.3)	System Integration, Master Test Plan (69 Test Cases), Bidirectional RTM, Validation Criteria & 14 UAT Scenarios	IT-01..13, TC-REG..TC-NFR (69 TCs), S1..S14 (100% Coverage)

PART 1 — SYSTEM ANALYSIS, BEHAVIORAL UML DIAGRAMS & SYSTEM DESIGN INTERFACES (SDI)

Module Lead & Author: Aghapy Antonious | Banking Transaction System (BTS — Biscuit Bank Team)

1.1 Problem Statement

Traditional banking and financial transaction systems often suffer from critical architectural vulnerabilities, security flaws, and data inconsistency risks. Specifically, the Banking Transaction System (BTS) addresses the following core problems:

- **Authorization & Privilege Escalation (Security & IDOR Flaws):** Inadequate role segregation where administrative accounts might improperly access or execute customer-level financial operations (violating strict Role-Based Access Control), or where a customer can probe another customer's account resources via Insecure Direct Object References (IDOR).
- **Duplicate Transaction Risks (Idempotency Issues):** Network glitches, timeouts, or client-side double-submissions can trigger duplicate fund transfers, leading to severe financial discrepancies and ledger corruption.
- **Lack of State Validation, Precision & Atomic Integrity:** Executing money transfers without proper verification of 12-Digit Luhn account numbers, account statuses (ACTIVE vs. FROZEN or CLOSED), product balance thresholds (Savings minimum 1,000.00 EGP; Checking overdraft -1,000.00 EGP), integer piaster precision (1 EGP = 100 Piasters), or failing to ensure atomic transactions across ledger entries (TRANSFER_OUT, TRANSFER_IN, and FEE).

1.2 Project Objectives

The primary objective of the Banking Transaction System (BTS) — developed by the Biscuit Bank Team — is to design and implement a secure, robust, and scalable Layered Modular Monolith banking application (Java 21, Spring Boot 3.5, SQLite WAL) that resolves the aforementioned problems through the following mechanisms:

- **Enforcing Strict Role-Based Security & IDOR Protection (US-04, US-25):** Integrate Spring Security 6.x principles to enforce strict isolation between CUSTOMER and ADMIN roles. Admin users attempting to access customer financial endpoints are automatically intercepted and blocked with HTTP 403 Forbidden, while cross-customer resource requests return a uniform HTTP 404 ACCOUNT_NOT_FOUND response.
- **Guaranteeing Idempotency & Upfront Fee Transparency for Financial Operations (US-15, US-16):** Implement an upfront InstaPay Fee Quote (0.1%, Min 0.50 EGP, Max 20.00 EGP) and an Idempotency-Key mechanism within the service layer. Every transfer request carries a unique key so that repeated requests within 24 hours return the cached response without executing a duplicate financial transfer.
- **Robust Domain & Account Status Validation in Integer Piasters (US-06..09, US-22, DOM-01):** Implement pre-execution validations in the Domain Layer to verify 12-Digit Luhn check digits, check account statuses (ACTIVE vs. FROZEN/CLOSED), enforce Savings/Checking/FD rules, and store all monetary values strictly in BIGINT piasters.
- **Atomic SQLite WAL Ledger & Immutable Audit Transactions (NFR-03, NFR-04, US-24):** Ensure that all financial movements (debit, credit, fee calculation, append-only ledger rows, and tamper-evident security audit logs) are processed atomically inside a single @Transactional SQLite Write-Ahead Logging (WAL) transaction to prevent partial updates.

1.3 Use Case Diagram & Functional Scope

The Use Case Diagram models the functional interactions between the three external actors—Customer, Bank Administrator, and System Scheduler—and the 25 User Stories (US-01 to US-25) inside the Banking Transaction System (BTS) boundary.

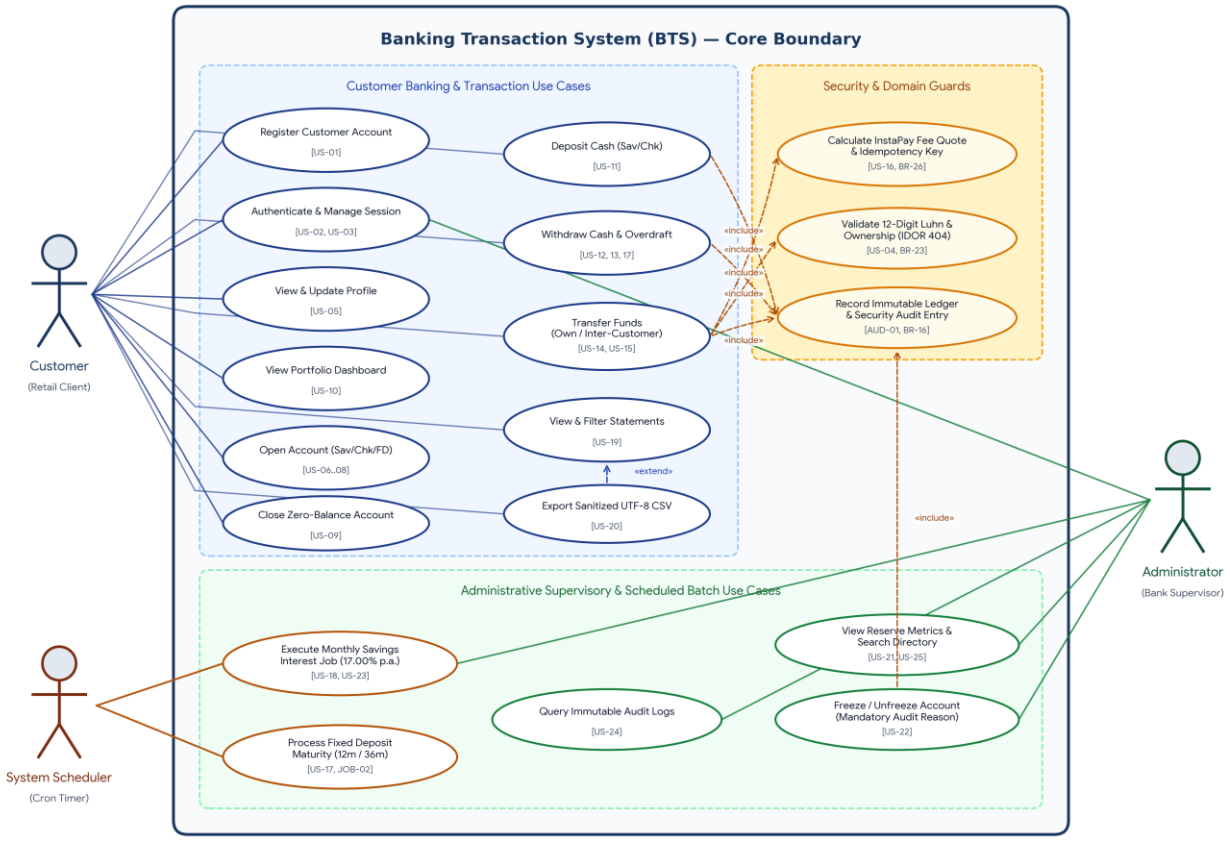


Figure 1.1 — BTS UML Use Case Diagram (Actors, Functional Packages, and «include» / «extend» Dependencies)

Actor	Assigned Use Cases	Key Business & Security Constraints	Jira Req IDs
Customer (Retail Client)	• Register & Authenticate Session • View & Update Personal Profile • View Portfolio Dashboard • Open Savings / Checking / FD Account • Close Zero-Balance Active Account • Deposit & Withdraw Cash • Preview Fee Quote & Transfer Funds • View Statements & Export UTF-8 CSV	• Max 5 non-closed accounts per customer (BR-22). • Savings min balance 1,000.00 EGP (BR-07); Checking overdraft down to -1,000.00 EGP (BR-10). • Cross-customer access returns HTTP 404 ACCOUNT_NOT_FOUND (IDOR Guard, SEC-02). • CSV export neutralizes '=', '+', '-', '@' formula prefixes (STM-03).	**US-01 to US-16, US-19, US-20**
Administrator (Bank Supervisor)	• Authenticate Admin Session • View Bank Reserve Metrics & Totals • Search Customer & Account Directory • Freeze / Unfreeze Customer Account • Trigger Monthly Interest Job Manually • Query Immutable Security Audit Logs	• Strict separation of duties: Admin cannot hold accounts or execute deposits, withdrawals, or transfers (HTTP 403 Forbidden, ADM-07, US-25). • Freeze/Unfreeze requires a mandatory non-empty reason (<= 255 chars) logged in Audit Trail (US-22). • Zero password hash exposure in views/DTOs (SEC-08).	**US-02, US-03, US-21 to US-25**
System Scheduler (Cron Timer)	• Execute Monthly Savings Interest Accrual (17.00% p.a. / 12) • Process Fixed Deposit Maturity (12m @ 17.00% / 36m @ 17.75%)	• Runs under actor SYSTEM using injected java.time.Clock (NFR-05). • Idempotent execution: credits qualifying ACTIVE accounts at most once per cycle (BR-08, BR-15).	**US-17, US-18, JOB-01, JOB-02**

1.4 Sequence Diagram (Atomic Transfer & Upfront Fee Quote)

Figure 1.2 illustrates the chronological message exchange across the layered architecture during a two-phase Inter-Customer Money Transfer: Phase 1 calculates the upfront InstaPay fee quote and issues a time-bound Idempotency-Key (US-16), and Phase 2 executes the atomic SQLite WAL balance update, immutable ledger insertion, and audit trail logging (US-15).

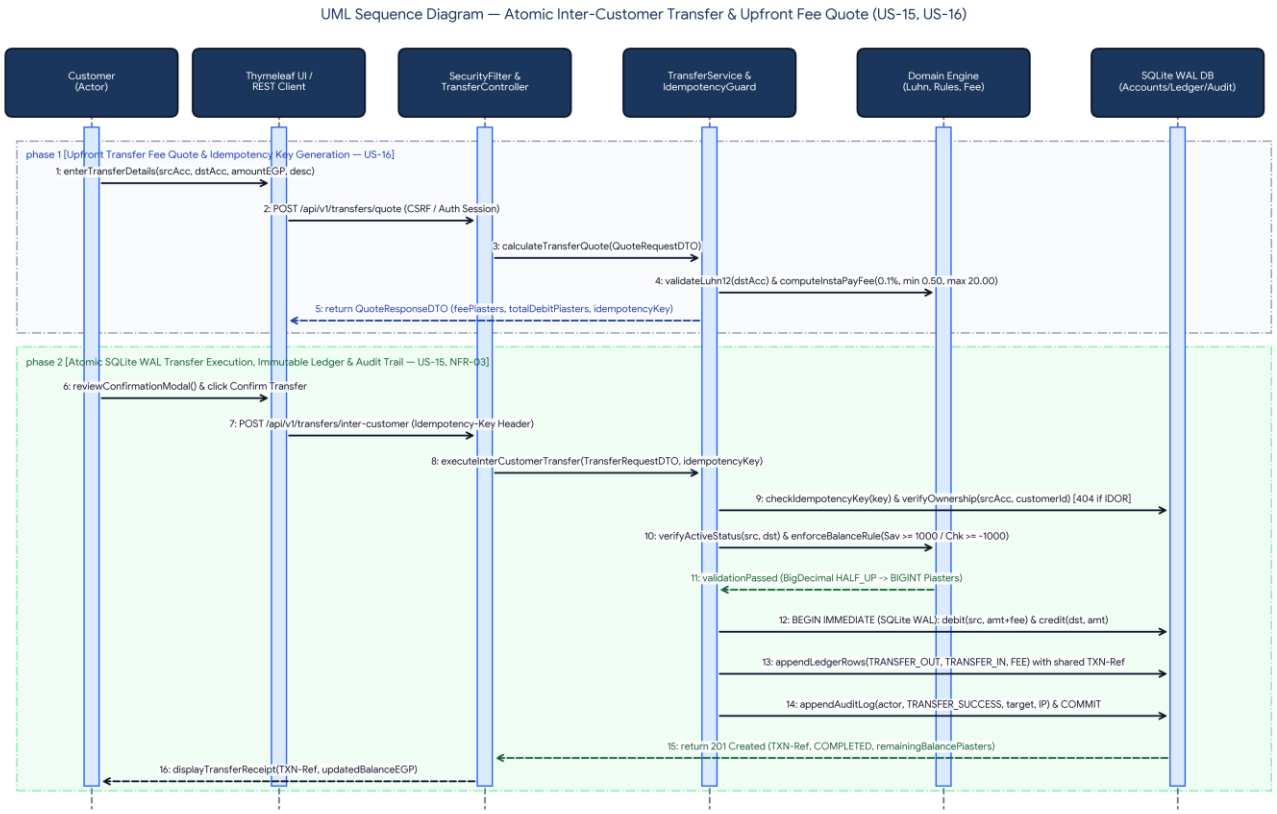


Figure 1.2 — UML Sequence Diagram for Upfront Fee Quote & Atomic Inter-Customer Transfer Execution

1.5 Activity Diagram (Transfer Validation & Decision Flow)

Figure 1.3 models the complete control flow and business rule decision guards for money movement, including RBAC role verification (blocking Admin with HTTP 403), 12-Digit Luhn validation, HTTP 404 IDOR ownership verification, account status checks (ACTIVE vs. FROZEN), transfer type fee branching (Own-Account vs. Inter-Customer InstaPay fee), product balance thresholds, and transactional rollback handling.

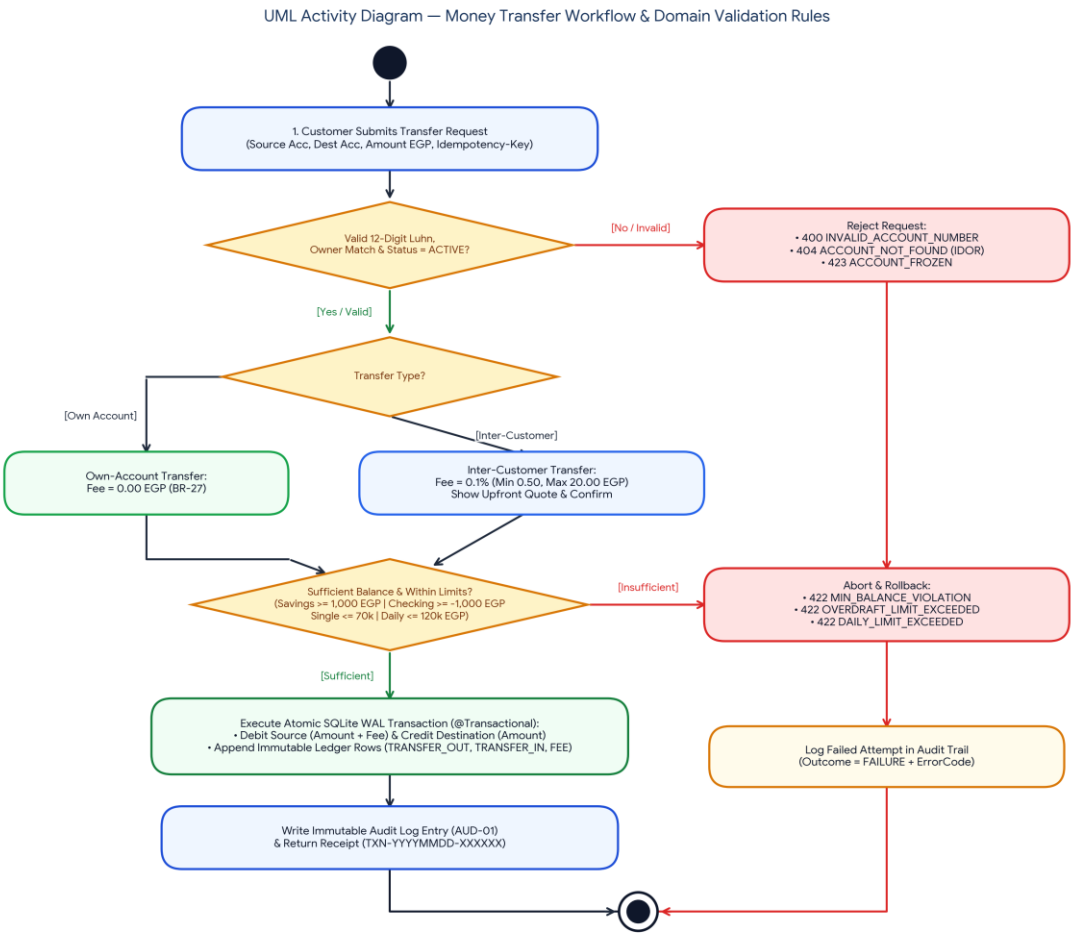


Figure 1.3 — UML Activity Diagram for Money Transfer Validation, Fee Branching & Atomic Commit/Rollback

1.6 System Design Interfaces (SDI)

The Banking Transaction System (BTS) enforces a strict Layered Modular Monolith architecture (NFR-08) where each layer communicates exclusively with its adjacent layer through well-defined Java interfaces and validated Data Transfer Objects (DTOs):

Interface / Component	Layer	Key Methods / Operations (Signatures)	Responsibility & Contract Rules
CustomerWebUI & AdminConsoleUI	Presentation Layer (Thymeleaf Views)	• renderTransferForm(accountsList) • displayFeeQuoteModal(quoteDto) • renderStatementTable(page, filters) • showStatusBanner(domId, message)	Binds form inputs to DTOs, embeds hidden _csrf synchronizer tokens, displays upfront fee quotes before confirmation, and exposes permanent DOM IDs for Selenium 4 POM tests (NFR-05, NFR-06).
AuthController & AccountController	Controller Layer (Web MVC / REST)	• registerCustomer(@Valid RegisterRequestDto) • authenticate(@Valid LoginRequestDto) • openAccount(@Valid OpenAccountDto) • closeAccount(accountNumber)	Validates DTO field constraints, rotates HTTP session IDs on login, enforces 12-Digit Luhn format pre-check, and delegates business execution to Service interfaces (AUTH-01..07, ACC-01..07).
TransferController & StatementController	Controller Layer (Web MVC / REST)	• getTransferQuote(@Valid QuoteRequestDto) • executeTransfer(idempotencyKey, @Valid TransferDto) • getStatements(accountNo, filterDto, Pageable) • exportStatementsCsv(accountNo, filterDto)	Accepts Idempotency-Key headers on money-moving POSTs, enforces pagination bounds (default 10, max 100 rows), and streams formula-sanitized UTF-8 CSV files (TXN-07..09, STM-01..03).
AdminController	Controller Layer (Admin Portal)	• getReserveDashboardMetrics() • searchDirectory(query, filterDto) • updateFreezeState(accountNo, @Valid FreezeDto)	Restricted strictly to ROLE_ADMIN. Enforces mandatory non-empty reason (<= 255 chars) on freeze/unfreeze and blocks admin access to customer money endpoints with HTTP 403

		• triggerInterestJobManually() • queryAuditLogs(AuditFilterDto, Pageable)	(ADM-01..07).
TransferService & AccountService	Application Service Layer	• previewQuote(customerId, QuoteRequestDto) • processTransfer(customerId, key, TransferDto) • deposit(customerId, DepositDto) • withdraw(customerId, WithdrawDto)	Verifies account ownership (throwing 404 AccountNotFoundException on IDOR attempts), checks Idempotency-Key store, and wraps balance + ledger updates in one atomic transaction (TXN-01..06).
LuhnValidator & FeeCalculator & PiasterConverter	Core Banking Domain Layer	• isValidLuhn12(accountNumber) • generateUniqueLuhn12() • calculateInstaPayFee(amountPiasters) • toPiasters(BigDecimal) / toEgp(long)	Pure domain logic verified with >= 90% JUnit 5 & JaCoCo coverage. Converts EGP (scale 2, HALF_UP) to BIGINT piasters and computes 0.1% fee (min 50, max 2000 piasters) (BR-01, BR-23, BR-26).
InterestScheduler & AuditLogService	Service / Cross-Cutting Layer	• runMonthlySavingsInterestJob(Clock) • runFixedDepositMaturityJob(Clock) • recordAuditEvent(AuditEntryDto)	Uses injected java.time.Clock for deterministic scheduling, prevents duplicate monthly/maturity interest postings, and writes tamper-evident audit logs without sensitive secrets (JOB-01..02, AUD-01..02).
AccountRepository, LedgerRepository & AuditLogRepository	Data Persistence Layer (SQLite WAL)	• findByAccountNumberForUpdate(accountNo) • saveAccountBalancePiasters(AccountEntity) • appendLedgerEntry(LedgerEntryEntity) • findFilteredAuditLogs(Specification, Pageable)	Executes parameterized JPA queries over a single-connection HikariCP pool in SQLite WAL mode (busy_timeout=5000, BEGIN IMMEDIATE). Ledger and Audit repositories expose append/read only (no UPDATE/DELETE) (NFR-03, BR-16).

PART 2 — DATABASE DESIGN, ENTITY-RELATIONSHIP DIAGRAM (ERD), CLASS & STATE MACHINE DIAGRAMS

Module Lead & Author: Aladdin Ahmed | Banking Transaction System (BTS — Biscuit Bank Team)

2.1 Entity-Relationship Diagram (ERD) & SQLite WAL Schema

The Entity-Relationship Diagram (ERD) establishes the physical data architecture, primary/foreign key constraints, and structural cardinalities of the Banking Transaction System (BTS) persisted in an embedded SQLite database configured in Write-Ahead Logging (WAL) mode (NFR-03). All monetary balances, transaction amounts, overdraft limits, and fees are stored strictly as 64-bit signed integers (BIGINT Piasters, where 1 EGP = 100 Piasters) to eliminate floating-point rounding drift (NFR-01, BR-01).

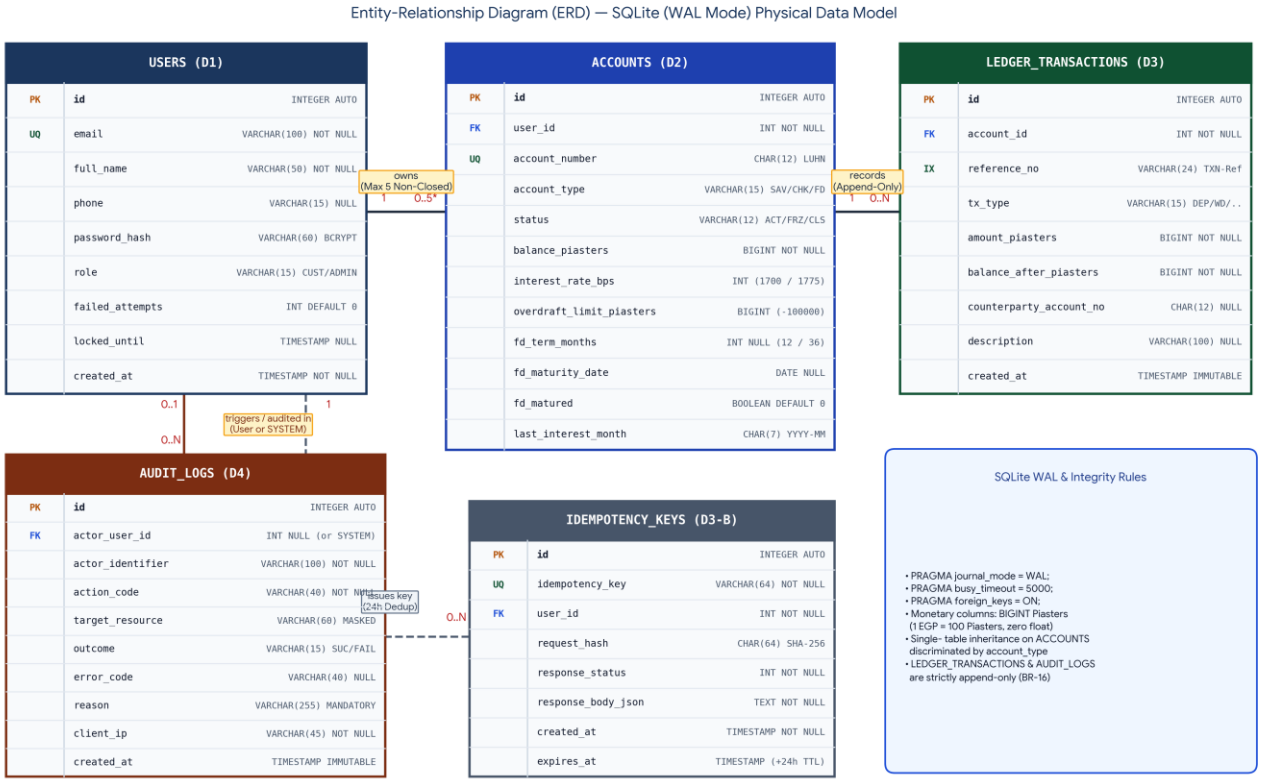


Figure 2.1 — BTS Entity-Relationship Diagram (Crow's Foot Notation — SQLite WAL Physical Data Model)

Table Name	Primary / Unique Keys	Foreign Keys & Indexes	Core Columns & Domain Constraints
USERS (Store D1)	• PK: id • UQ: LOWER(email)	• IX: idx_users_email • IX: idx_users_role	full_name (2..50 chars), email (<=100 chars, case-insensitive unique, BR-24), phone (10..15 digits, optional), password_hash (BCrypt cost >= 10), role (CUSTOMER / ADMIN), failed_attempts (0..5), locked_until (15-min lockout timestamp, US-02).
ACCOUNTS (Store D2)	• PK: id • UQ: account_number	• FK: user_id -> USERS(id) • IX: idx_acc_user_status	account_number (12 numeric digits, Luhn validated, never reissued, BR-23), account_type (SAVINGS, CHECKING, FIXED_DEPOSIT), status (ACTIVE, FROZEN, CLOSED), balance_piasters (BIGINT), interest_rate_bps (1700 or 1775), overdraft_limit_piasters (-100000), fd_term_months (12 or 36), fd_maturity_date, last_interest_month.
LEDGER_TRANSACTIONS (Store D3)	• PK: id	• FK: account_id -> ACCOUNTS(id) • IX: idx_led_acc_created • IX: idx_led_ref_no	reference_no (TXN-YYYYMMDD-XXXXXX), tx_type (DEPOSIT, WITHDRAWAL, TRANSFER_OUT, TRANSFER_IN, FEE, INTEREST), amount_piasters (BIGINT > 0), balance_after_piasters (BIGINT), counterparty_account_no

			(CHAR(12)), description (<=100 chars), created_at. Strictly append-only (no UPDATE/DELETE).
IDEMPOTENCY_KEYS (Store D3-B)	• PK: id • UQ: idempotency_key	• FK: user_id -> USERS(id) • IX: idx_idem_expires	idempotency_key (VARCHAR(64)), request_hash (SHA-256 of payload), response_status (HTTP code), response_body_json (cached JSON response), created_at, expires_at (created_at + 24 hours, BR-19).
AUDIT_LOGS (Store D4)	• PK: id	• FK: actor_user_id -> USERS(id) NULL • IX: idx_aud_created_action	actor_identifier (email or 'SYSTEM'), action_code (REGISTER, LOGIN_SUCCESS, LOGIN_FAILURE, ACCOUNT_LOCKED, ACCOUNT_OPEN, ACCOUNT_CLOSE, ACCOUNT_FROZEN, ACCOUNT_UNFROZEN, TRANSFER, JOB_TRIGGER), target_resource (masked account 7701), outcome (SUCCESS/FAILURE), reason (<=255 chars), client_ip, created_at.

2.2 Class Diagram (Object-Oriented Domain Hierarchy)

The Class Diagram models the object-oriented domain hierarchy implemented in Java 21 and Spring Boot 3.5. It encapsulates all core banking invariants, polymorphic account behaviors, BigDecimal-to-Piaster conversions, and immutable transaction/audit entities verified with >= 90% JUnit 5 and JaCoCo unit test coverage (DOM-05).



Figure 2.2 — BTS UML Class Diagram (Domain Entities, Account Inheritance Hierarchy & Audit Models)

2.3 State Machine Diagram (Bank Account Lifecycle)

The State Machine Diagram governs the operational states (ACTIVE, FROZEN, and CLOSED) and transition guard conditions for bank accounts in the Banking Transaction System (BR-20, BR-21).

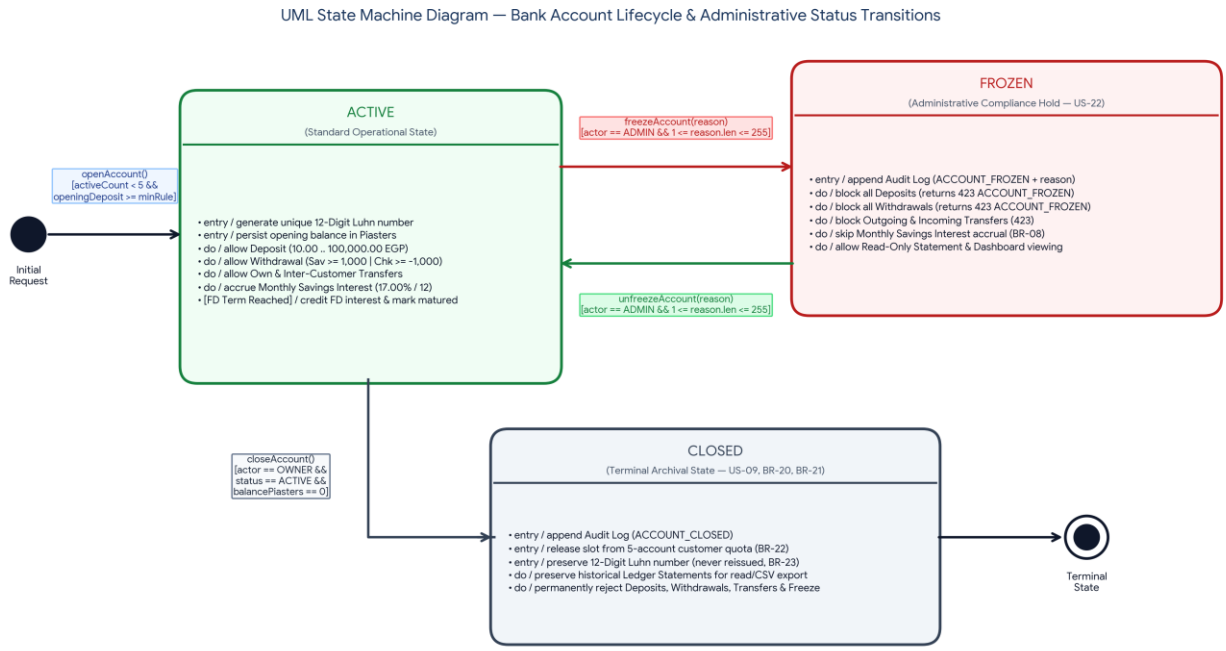


Figure 2.3 — UML State Machine Diagram for Bank Account Lifecycle (ACTIVE, FROZEN & CLOSED States)

State	Operational Permissions & Restrictions	Allowed Outgoing Transitions & Guards	Related Req IDs
ACTIVE	• Permits cash deposits (Savings & Checking), withdrawals within product limits, own-account & inter-customer transfers, and monthly/maturity interest accruals. • Counts toward the customer's 5-account limit (BR-22).	1. ACTIVE -> FROZEN: Triggered by ADMIN via freezeAccount(reason) with a mandatory non-empty reason (1..255 chars). 2. ACTIVE -> CLOSED: Triggered by account owner via closeAccount() ONLY when balancePiasters == 0 (rejects positive or negative overdraft balances with NON_ZERO_BALANCE).	**US-06..09, US-11..18, BR-20, BR-21**
FROZEN	• Triggered when an administrator places a compliance hold on a suspicious account. • Blocks all deposits, withdrawals, and incoming/outgoing transfers (returns HTTP 423/422 ACCOUNT_FROZEN). • Excluded from monthly Savings interest accrual runs (BR-08). Cannot be closed directly while frozen (ACCOUNT_NOT_ACTIVE). • Still counts toward the 5-account limit and remains visible on customer dashboard.	1. FROZEN -> ACTIVE: Triggered by ADMIN via unfreezeAccount(reason) with a mandatory non-empty audit reason (1..255 chars); logs ACCOUNT_UNFROZEN in Audit Trail.	**US-22, US-24, ACC-05, BR-08, BR-20**
CLOSED (Terminal)	• Terminal archival state reached when an ACTIVE account with exactly 0.00 EGP balance is closed. • Permanently rejects deposits, withdrawals, transfers, and administrative freeze/unfreeze (ACCOUNT_CLOSED). • Preserves historical ledger statements for viewing and CSV export (ACC-04). • Excluded from portfolio total balance and frees 1 slot in the customer's 5-account quota (BR-22). The 12-Digit Luhn number is never reissued (BR-23).	• None (Terminal State — no outgoing transitions permitted).	**US-09, ACC-04, BR-20, BR-21, BR-22, BR-23**

PART 3 — SYSTEM ARCHITECTURE, COMPONENT & DATA FLOW DIAGRAMS (DFD), AND RESTFUL API SPECIFICATION

Module Lead & Author: Muhammad Sayyid | Banking Transaction System (BTS — Biscuit Bank Team)

3.1 Architectural Pattern & Approved Technology Stack

The Banking Transaction System (BTS) is engineered as a strict Layered Modular Monolith (Controller -> Security -> Service -> Domain -> Repository -> SQLite WAL Database) (NFR-08, ARCH-01). This pattern guarantees clear separation of concerns, zero business logic leakage into web templates or controllers, deterministic unit and integration testability via an injected java.time.Clock (NFR-05), and serialized ACID write transactions without external database server dependencies (NFR-09).

Architectural Layer / Concern	Selected Technology / Standard	Justification & Requirement Alignment
Core Language & Runtime	Java 21 LTS	Modern type safety, records for immutable DTOs, and deterministic BigDecimal arithmetic (NFR-01).
Application Framework	Spring Boot 3.5 (Spring MVC, Spring Data JPA)	Production-grade dependency injection, declarative @Transactional rollback management, and embedded server portability (NFR-08, NFR-09).
Server-Side Web UI	Thymeleaf + Responsive HTML5 / CSS3	Auto-escaped template rendering (XSS prevention), automatic _csrf hidden token binding, and permanent DOM IDs for Selenium 4 POM tests (SEC-04, SEC-05, NFR-05).
Security & Access Control	Spring Security 6.x + BCrypt (cost >= 10)	Deny-by-default routing, RBAC (CUSTOMER vs. ADMIN), 5-attempt / 15-min lockout, 15-min idle session timeout, session fixation rotation, CSP/X-Frame headers, and Rate Limiting (SEC-01..11).
Database & Concurrency Engine	SQLite 3 (WAL Mode) + HikariCP (max-pool-size=1)	PRAGMA journal_mode=WAL, busy_timeout=5000ms, and BEGIN IMMEDIATE write locks guarantee zero SQLITE_BUSY errors and zero lost updates under parallel requests (ARCH-01, NFR-03).
Monetary Representation	BIGINT Integer Piasters (DB) <-> BigDecimal (Domain)	JPA AttributeConverter maps EGP BigDecimal (scale 2, RoundingMode.HALF_UP) to 64-bit integer Piasters (1 EGP = 100 Piasters); zero float/double/REAL usage (NFR-01, BR-01).
API Documentation	Springdoc OpenAPI 3 / Swagger UI	Auto-generated interactive REST specification under dev profile; restricted/disabled in production (NFR-10, SEC-08).
Quality Assurance & Security Tooling	JUnit 5, JaCoCo (>=90%), MockMvc, Postman, Selenium 4 (POM), SonarLint, SpotBugs, OWASP Dependency-Check	Full verification across unit, integration, concurrency, API latency (<500ms P95), UI E2E, static analysis, and CVE scanning (QA-01..04, DOM-05, NFR-02).

3.2 Component Architecture & Defense-in-Depth Security Pipeline

Figure 3.1 illustrates the six-tier internal component architecture of the Banking Transaction System, highlighting the Spring Security 6.x filter chain, MVC/REST controllers, transactional application services, pure Java financial domain engine, and SQLite WAL persistence stores.

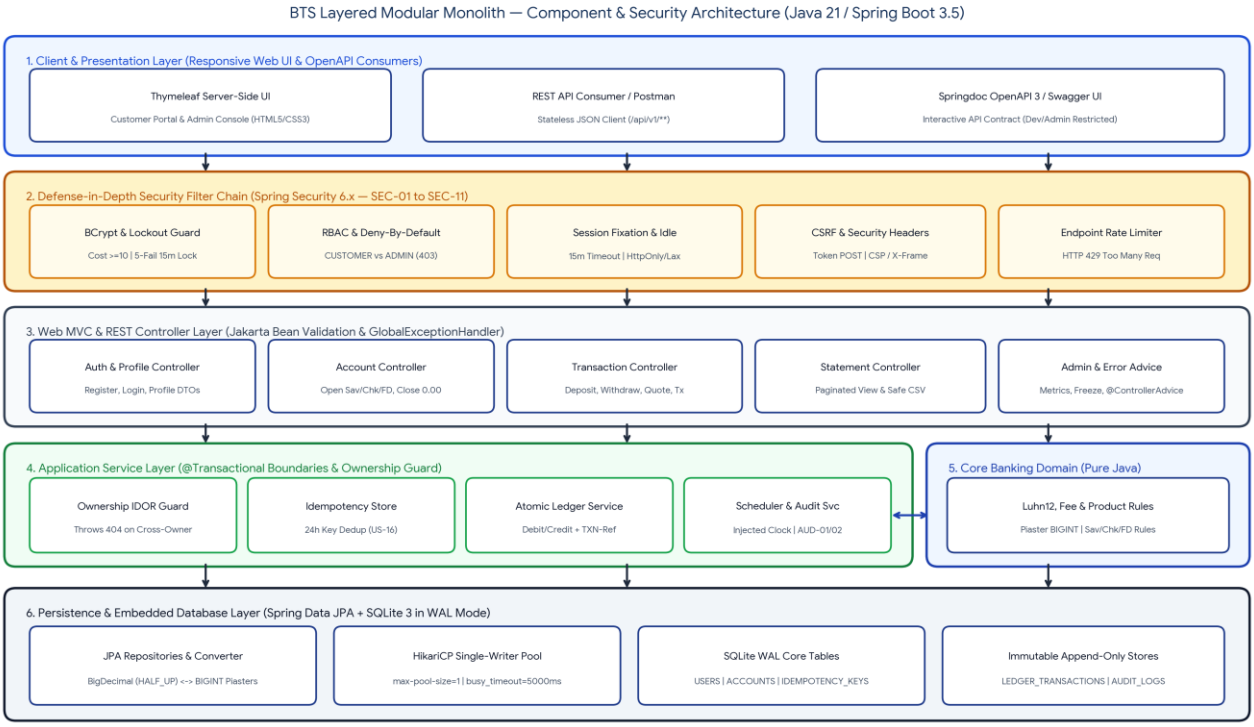


Figure 3.1 — BTS Layered Modular Monolith Component & Defense-in-Depth Security Architecture

3.3 Data Flow Diagrams (DFD Level 0 & Level 1)

Figure 3.2 (DFD Level 0 Context Diagram) defines the external boundaries and data exchanges between the Customer, Bank Administrator, System Clock/Scheduler, and the central BTS process. Figure 3.3 (DFD Level 1 Decomposition) breaks the system into six core functional processes (P1.0 to P6.0) interacting with the four SQLite WAL data stores (D1 to D4).

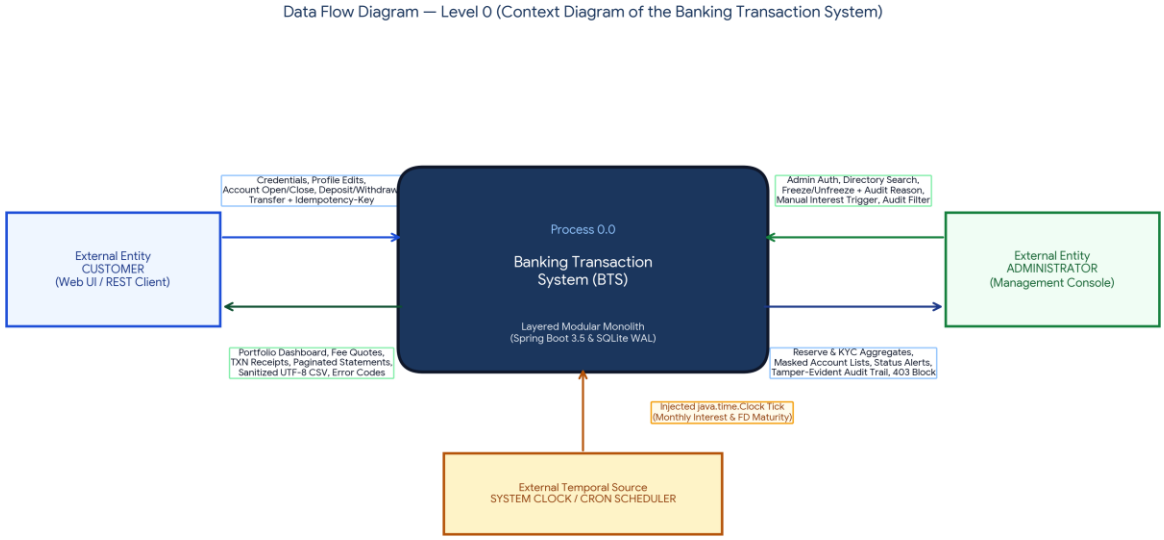


Figure 3.2 — Data Flow Diagram Level 0 (Context Diagram of the Banking Transaction System)

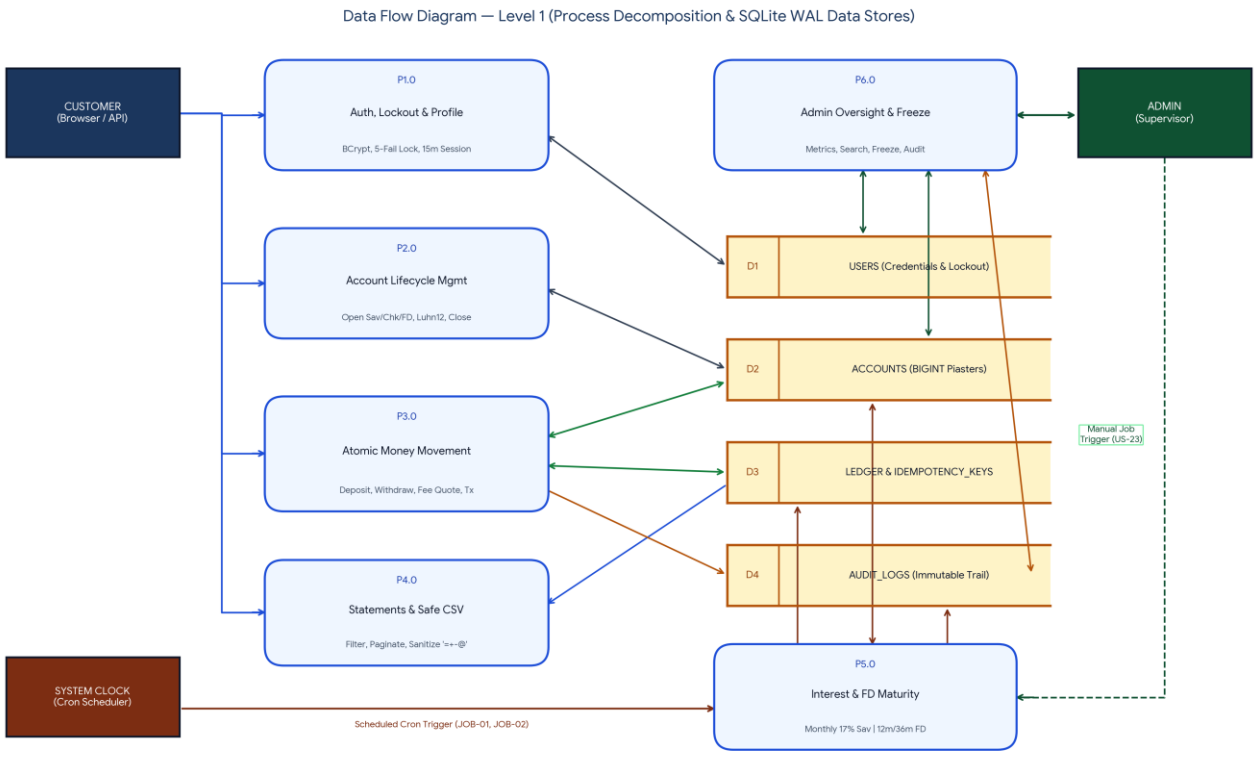


Figure 3.3 — Data Flow Diagram Level 1 (Process Decomposition P1.0–P6.0 & Data Stores D1–D4)

3.4 RESTful API Specification & Endpoint Catalogue

All REST API endpoints under /api/v1/** authenticate statelessly via HTTP Basic (or authenticated session context), accept and return UTF-8 JSON payloads validated by Jakarta Bean Validation, and enforce strict role and account-ownership authorization (AUTH-02, AUTH-03, SEC-01, SEC-02).

Method & Endpoint Path	Role / Auth	Request Payload / Headers / Params	Success Response & Domain Behavior	User Story & Req ID
POST /api/v1/auth/register	Public	JSON: fullName (2..50 chars), email, phone (optional, 10..15 digits), password (8..64 chars, upper/lower/digit)	201 Created: Atomically creates User + Profile with salted BCrypt hash; rejects duplicate email (case-insensitive) with 409 DUPLICATE_EMAIL; logs REGISTER event.	**US-01, AUTH-01, AUTH-05, BR-24**
POST /api/v1/auth/login	Public	JSON / Form: email, password	200 OK: Rotates Session ID (session fixation guard); increments failed_attempts on error; locks account for 15m after 5th failure (ACCOUNT_LOCKED); generic error message.	**US-02, AUTH-02, AUTH-06, SEC-03, SEC-09**
POST /api/v1/auth/logout	CUSTOMER / ADMIN	Active HTTP Session + CSRF Token	200 OK / 302 Redirect: Immediately invalidates HTTP session and clears HttpOnly/SameSite=Lax cookie.	**US-03, AUTH-07, SEC-06**
GET /api/v1/profile **PUT /api/v1/profile**	CUSTOMER	PUT JSON: fullName, phone (email is immutable read-only)	200 OK: Returns or updates customer profile; rejects invalid name/phone with 400 field-level validation errors.	**US-05, CUS-01, CUS-02**
GET /api/v1/dashboard	CUSTOMER	Authenticated Customer Context	200 OK: Lists all customer accounts (type, 12-digit Luhn number, status, balance EGP) and total portfolio balance (excluding CLOSED accounts).	**US-10, CUS-03, ACC-03**
POST /api/v1/accounts	CUSTOMER	JSON: accountType (SAVINGS | CHECKING |	201 Created: Enforces max 5 non-closed accounts (422	**US-06, US-07, US-08, ACC-01,**

		FIXED_DEPOSIT), openingDepositEgp, termMonths (12 or 36 for FD)	MAX_ACCOUNTS_EXCEEDED), Sav >= 1,000 EGP, Chk >= 0 EGP (<=100k), FD >= 5,000 EGP (12m@17% / 36m@17.75%); generates unique 12-Digit Luhn number.	**ACC-02, ACC-06, BR-07..12**
GET /api/v1/accounts/{accountNo}	CUSTOMER	Path: 12-Digit Luhn accountNo	200 OK: Returns product details (rate/min balance, overdraft limit, or FD term/maturity date). Returns 404 ACCOUNT_NOT_FOUND if owned by another customer (IDOR guard).	**US-04, US-10, ACC-03, SEC-02**
POST /api/v1/accounts/{accountNo}/close	CUSTOMER	Path: 12-Digit Luhn accountNo	200 OK: Transitions ACTIVE account with 0.00 EGP balance to CLOSED; rejects non-zero/overdrawn balance (422 NON_ZERO_BALANCE) or frozen account (422 ACCOUNT_NOT_ACTIVE).	**US-09, ACC-04, BR-20, BR-21**
POST /api/v1/transactions/deposit	CUSTOMER	Header: Idempotency-Key JSON: accountNumber, amountEgp (10.00..100,000.00), description	201 Created: Credits ACTIVE Savings/Checking account in BIGINT piasters and appends DEPOSIT ledger row; rejects FD (422 FD_DEPOSIT_NOT_ALLOWED), Frozen (423), Closed, or IDOR (404).	**US-11, TXN-01, TXN-04, BR-02, BR-13**
POST /api/v1/transactions/withdraw	CUSTOMER	Header: Idempotency-Key JSON: accountNumber, amountEgp, description	201 Created: Enforces Sav min 1,000 EGP (MIN_BALANCE_VIOLATION), Chk overdraft >= -1,000 EGP (OVERDRAFT_LIMIT_EXCEEDED), single <=70k, daily <=120k, monthly <=400k, and FD maturity full-withdrawal rules.	**US-12, US-13, US-17, TXN-02, TXN-06, BR-05..14**
POST /api/v1/transfers/quote	CUSTOMER	JSON: sourceAccountNo, destinationAccountNo, amountEgp	200 OK: Validates Luhn12; returns upfront fee quote (0.00 EGP own-account; 0.1% HALF_UP min 0.50 max 20.00 EGP inter-customer), totalDebitEgp, masked recipient name, and Idempotency-Key without mutating balances.	**US-16, TXN-09, BR-26, BR-27**
POST /api/v1/transfers	CUSTOMER	Header: Idempotency-Key (24h dedup) JSON: sourceAccountNo, destinationAccountNo, amountEgp, description (<=100 chars)	201 Created: Atomically debits source (amount + fee), credits destination (amount), and appends TRANSFER_OUT, TRANSFER_IN, and FEE rows sharing one TXN-YYYYMMDD-XXXXXX reference; logs audit event.	**US-14, US-15, US-16, TXN-03..08, BR-18, BR-19, BR-28, BR-29**
GET /api/v1/accounts/{accountNo}/statements	CUSTOMER	Query: startDate, endDate, type, page (0..N), size (default 10, max 100)	200 OK: Returns newest-first ledger rows with running balanceAfterEgp; enforces ownership (404 on IDOR).	**US-19, STM-01, STM-02, BR-17**
GET /api/v1/accounts/{accountNo}/statements/export	CUSTOMER	Query: startDate, endDate, type	200 OK (text/csv; charset=UTF-8): Streams filtered statement CSV with formula-injection sanitization (neutralizing '=', '+', '-', '@' prefixes).	**US-20, STM-03**
GET /api/v1/admin/dashboard **GET /api/v1/admin/customers** **GET /api/v1/admin/accounts**	ADMIN	Query: q (customer search >=2 chars), accountNo, type, status, minBalance, maxBalance	200 OK: Returns total bank reserves (excluding CLOSED), customer/account counts, today's txns/fees, richest-customer report (handling ties), and filtered directory lists.	**US-21, US-25, ADM-01..04, BR-25**
POST /api/v1/admin/accounts/{accountNo}/freeze **POST /api/v1/admin/accounts/{accountNo}/unfreeze**	ADMIN	JSON: reason (mandatory non-empty, 1..255 chars)	200 OK: Transitions ACTIVE <-> FROZEN and writes mandatory justification reason to Audit Trail; rejects CLOSED account (422 ACCOUNT_CLOSED).	**US-22, ACC-05, BR-20, AUD-01**
POST /api/v1/admin/jobs/monthly-interest	ADMIN	Empty Body (Authenticated Admin)	200 OK: Idempotently triggers monthly Savings interest job (17.00% / 12) and FD maturity processing; credits each qualifying account at most once per cycle; writes audit entry.	**US-17, US-18, US-23, ADM-06, JOB-01, JOB-02**

GET /api/v1/admin/audit-logs	ADMIN	Query: startDate, endDate, actor, actionType, page, size	200 OK: Returns newest-first immutable audit entries (timestamp, actor, actionCode, masked target, outcome, reason, clientIp) with zero password/token exposure.	**US-24, US-25, ADM-05, AUD-01, AUD-02, SEC-11**

3.5 Standardized Global Error Handling & Error Code Catalogue (ARCH-02)

All domain, validation, security, and concurrency exceptions are intercepted by a centralized @RestControllerAdvice / @ControllerAdvice handler that returns a uniform JSON error envelope ({timestamp, status, errorCode, message, path, fieldErrors}) and suppresses internal stack traces (ARCH-02, SEC-08):

Error Code Identifier	HTTP Status	Triggering Condition & Business Rule	Linked Req / Rule
INVALID_AMOUNT / INVALID_OPENING_AMOUNT	400 Bad Request	Amount <= 0, more than 2 decimal places, non-numeric input, or Checking opening deposit > 100,000.00 EGP.	BR-01, BR-09, TXN-07
INVALID_ACCOUNT_NUMBER	400 Bad Request	Account number is not exactly 12 numeric digits or fails the Luhn check digit pre-check.	ACC-07, BR-23, DOM-01
SAME_ACCOUNT_TRANSFER	400 Bad Request	Source and destination account numbers are identical in a transfer request.	BR-28, TXN-03
INVALID_FD_TERM / UNSUPPORTED_CURRENCY	400 Bad Request	Fixed Deposit term is not 12 or 36 months, or currency is not EGP.	BR-03, BR-12
INVALID_SEARCH_QUERY	400 Bad Request	Administrator customer search query is empty or fewer than 2 trimmed characters.	ADM-02, BR-25
INVALID_CREDENTIALS / ACCOUNT_LOCKED	401 Unauthorized	Wrong email/password or account is locked for 15 minutes after 5 consecutive failed attempts (returns generic login message).	AUTH-02, AUTH-06, BR-24
ACCESS_DENIED / ADMIN_TXN_FORBIDDEN	403 Forbidden	Customer accesses /admin/ or Administrator attempts a deposit, withdrawal, transfer, or account opening.	AUTH-03, ADM-07, US-25
ACCOUNT_NOT_FOUND	404 Not Found	Target account does not exist OR belongs to another customer (uniform IDOR protection response).	AUTH-04, SEC-02, US-04
DUPLICATE_EMAIL / IDEMPOTENCY_CONFLICT	409 Conflict	Registration email already exists (case-insensitive) or Idempotency-Key is reused with a different request payload.	AUTH-01, BR-19, BR-24
DEPOSIT_LIMIT_EXCEEDED / TXN_LIMIT_EXCEEDED	422 Unprocessable	Deposit < 10.00 or > 100,000.00 EGP; single withdrawal/transfer > 70,000.00 EGP.	BR-02, BR-05
DAILY_LIMIT_EXCEEDED / MONTHLY_LIMIT_EXCEEDED	422 Unprocessable	Cumulative daily debit > 120,000.00 EGP or monthly debit > 400,000.00 EGP (excluding transfer fees).	BR-06, TXN-06
MIN_BALANCE_VIOLATION / MIN_OPENING_DEPOSIT_VIOLATION	422 Unprocessable	Savings opening/remaining balance < 1,000.00 EGP, or Fixed Deposit opening < 5,000.00 EGP.	BR-07, BR-11, US-06, US-12
OVERDRAFT_LIMIT_EXCEEDED	422 Unprocessable	Checking withdrawal or transfer would push balance below -1,000.00 EGP (-100,000 Piasters).	BR-10, US-13
FD_DEPOSIT_NOT_ALLOWED / FD_NOT_MATURE / FD_PARTIAL_WITHDRAWAL_NOT_ALLOWED	422 Unprocessable	Additional deposit into Fixed Deposit, withdrawal before maturity date, or partial withdrawal after maturity.	BR-13, BR-14, US-17
MAX_ACCOUNTS_EXCEEDED / NON_ZERO_BALANCE	422 Unprocessable	Customer already holds 5 non-closed accounts, or attempts to close an account with balance != 0.00 EGP.	ACC-04, ACC-06, BR-21, BR-22
ACCOUNT_FROZEN / ACCOUNT_CLOSED / ACCOUNT_NOT_ACTIVE	423 Locked / 422	Monetary operation attempted on a FROZEN or CLOSED account, or close attempted on a FROZEN account.	ACC-05, BR-20, US-22
INTEREST_ALREADY_POSTED / FD_INTEREST_ALREADY_CREDITED	409 / 422	Monthly Savings interest or FD maturity interest already credited for the current cycle.	BR-08, BR-15, JOB-01, JOB-02
RATE_LIMIT_EXCEEDED	429 Too Many Req	Client exceeds configured request rate threshold on authentication or money-moving endpoints.	SEC-09, SEC-TASK-01

TRANSFER_ATOMICITY_FAILURE / LEDGER_IMMUTABLE_VIOLATION	500 / 403	Forced/unexpected mid-transaction failure (triggers full SQLite WAL rollback) or prohibited ledger UPDATE/DELETE attempt.	NFR-03, NFR-04, BR-16, BR-29

PART 4 — UI/UX PROTOTYPE & INTERACTIVE WIREFRAMES (CUSTOMER PORTAL, ADMIN CONSOLE & MODALS)

Module Lead & Author: Asmaa Mohamed | Banking Transaction System (BTS — Biscuit Bank Team)

4.1 Design System, Accessibility & Interactive Prototype Link

The Banking Transaction System (BTS) user interface prototype is designed in Google Stitch following WCAG AA accessibility contrast standards (NFR-12), responsive viewport layouts (1366 px desktop and 375 px mobile, NFR-06), explicit label bindings, and permanent unique DOM element IDs to support automated Selenium 4 Page Object Model (POM) execution (NFR-05, UI-01, UI-02).

Interactive Google Stitch Prototype Preview Link: https://stitch.withgoogle.com/preview/6808874948880035503?node-id=96ca77e2f2e3497e86aedccbf40da2f5

4.2 Customer Portal Screens, Interactive Modals & Security Views (UI-01)

Customer Log In Screen (US-02, AUTH-02, AUTH-06, SEC-09): Displays the authenticated login gateway with email/password inputs, session protection notice ('login is temporarily locked for 15 minutes after 5 consecutive failed login attempts'), and quick prototype demo switches.

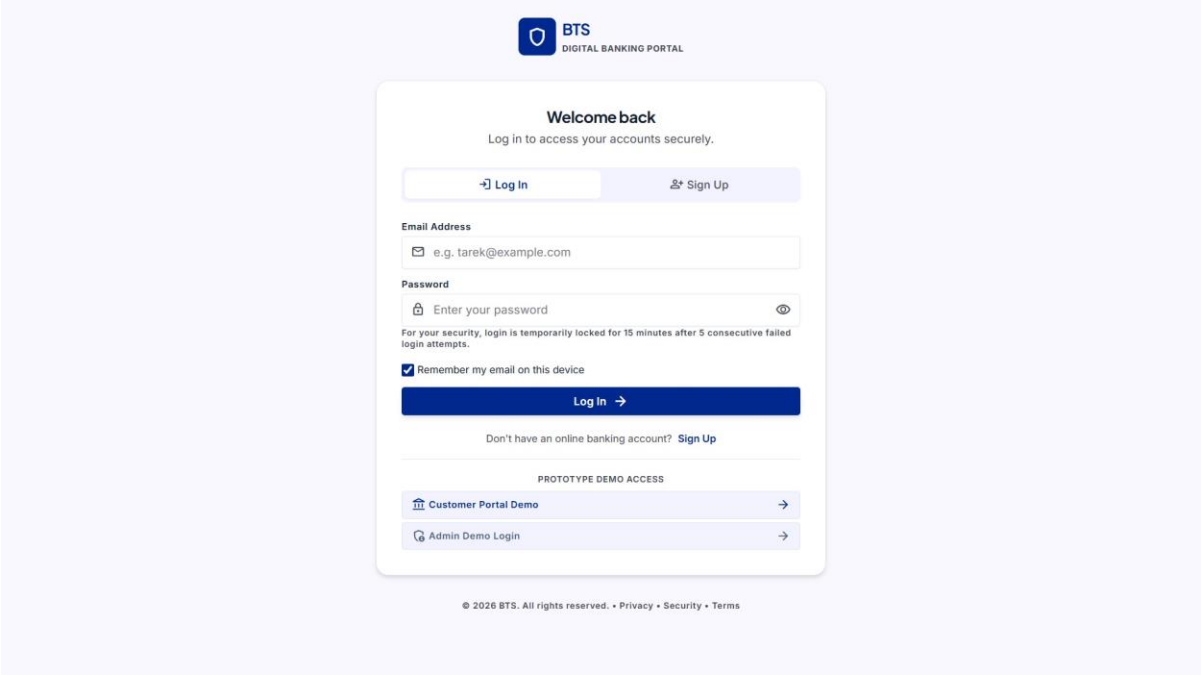


Figure 4.1 — Customer Log In Screen (US-02, AUTH-02, AUTH-06, SEC-09)

Customer Registration (Sign Up) Screen (US-01, AUTH-01, AUTH-05, CUS-02): Displays the 'Create your account' registration form capturing Full Legal Name (2..50 chars), Email Address (case-insensitive unique), Password (8..64 chars with complexity rules), and optional Phone Number (+201001234567).

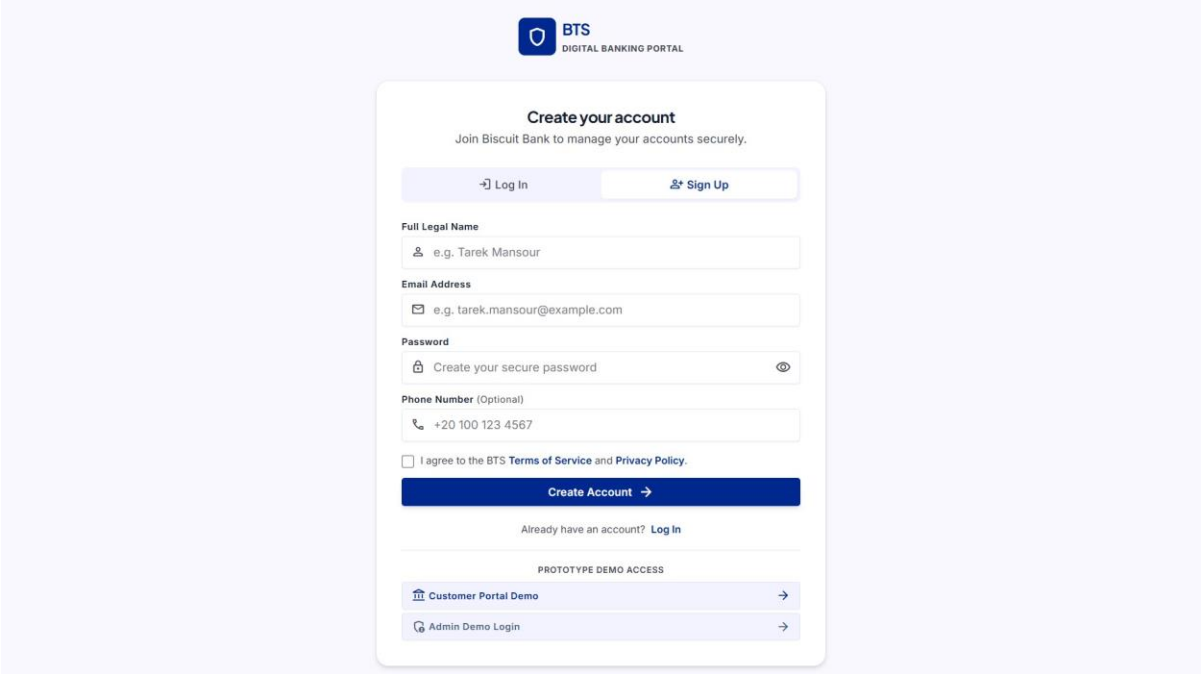


Figure 4.2 — Customer Registration (Sign Up) Screen (US-01, AUTH-01, AUTH-05, CUS-02)

Customer Portfolio Dashboard (US-10, CUS-03, ACC-03): Displays the authenticated customer's real-time portfolio summary (Account Limit: 3 of 5 active accounts used, Total Balance: EGP 482,450.00), quick action buttons (Deposit, Withdraw, Open New Account, Transfer Money), product cards (Checking, Savings, Fixed Deposit), and recent transactions.

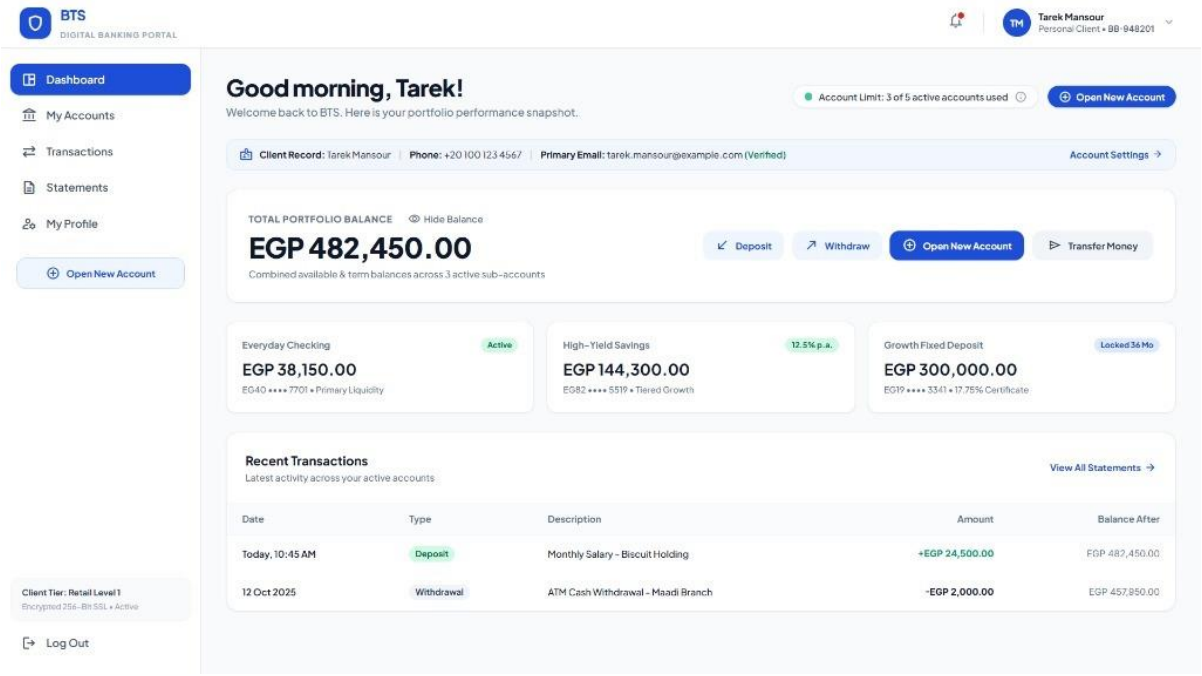


Figure 4.3 — Customer Portfolio Dashboard (US-10, CUS-03, ACC-03)

Open New Account Modal: Everyday Checking Option (US-07, ACC-01, BR-09): Interactive modal for opening a new Everyday Checking Account showing the customer's active quota (3 of 5 used), EGP 0.00 minimum opening deposit requirement, and quick deposit amount selectors.

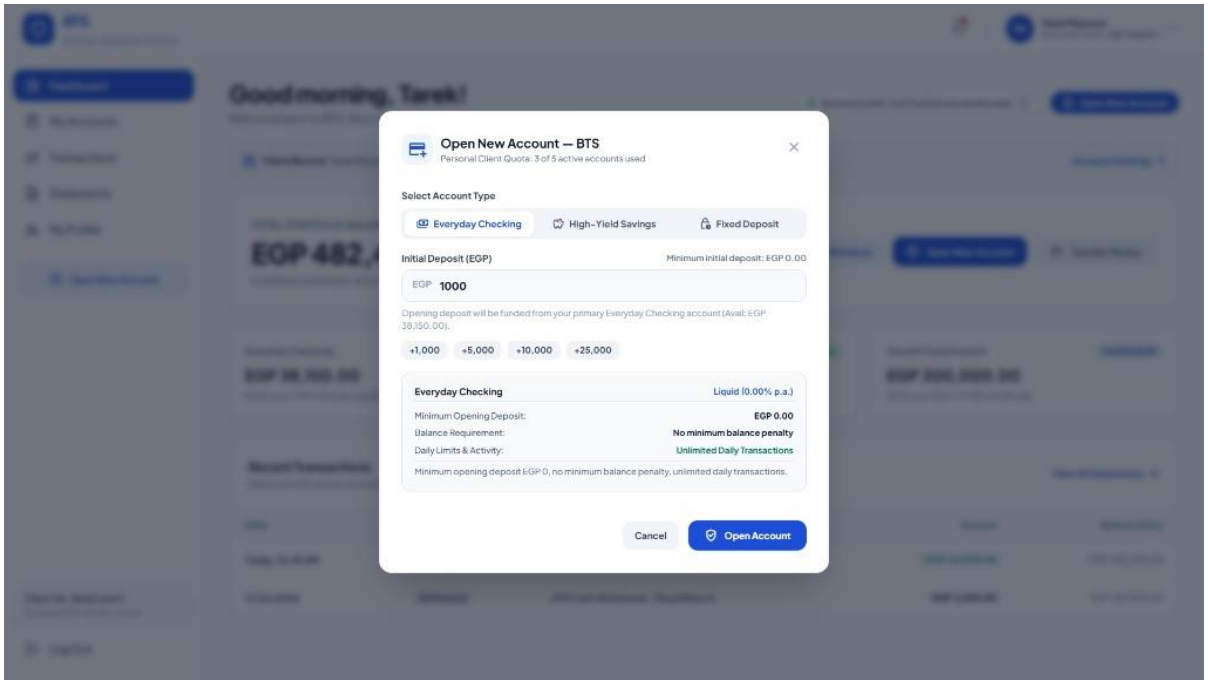


Figure 4.4 — Open New Account Modal: Everyday Checking Option (US-07, ACC-01, BR-09)

Open New Account Modal: High-Yield Savings Option (US-06, ACC-01, BR-07): Interactive modal for opening a High-Yield Savings Account enforcing the mandatory EGP 1,000.00 minimum opening deposit and ongoing EGP 1,000.00 minimum balance requirement.

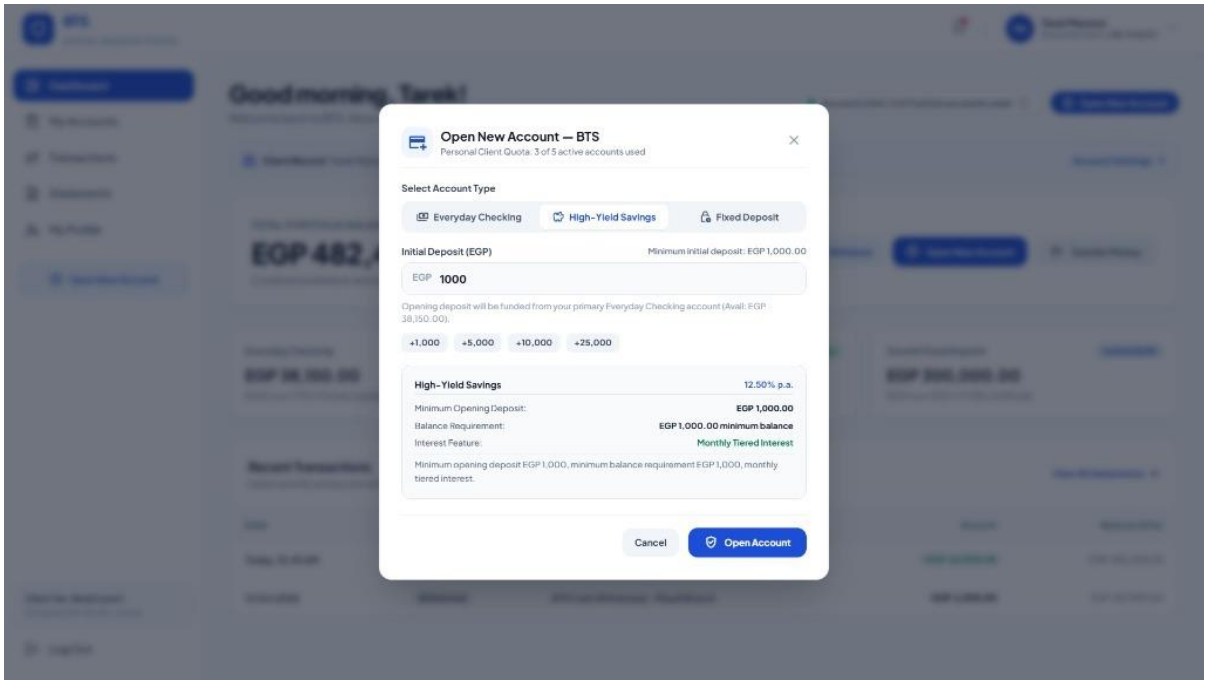


Figure 4.5 — Open New Account Modal: High-Yield Savings Option (US-06, ACC-01, BR-07)

Open New Account Modal: Fixed Deposit Certificate Option (US-08, ACC-01, BR-11, BR-12): Interactive modal for opening a locked Fixed Deposit Account enforcing the EGP 5,000.00 minimum opening deposit and selectable lock-in terms (12 Months @ 17.00% p.a. or 36 Months @ 17.75% p.a. paid at maturity).

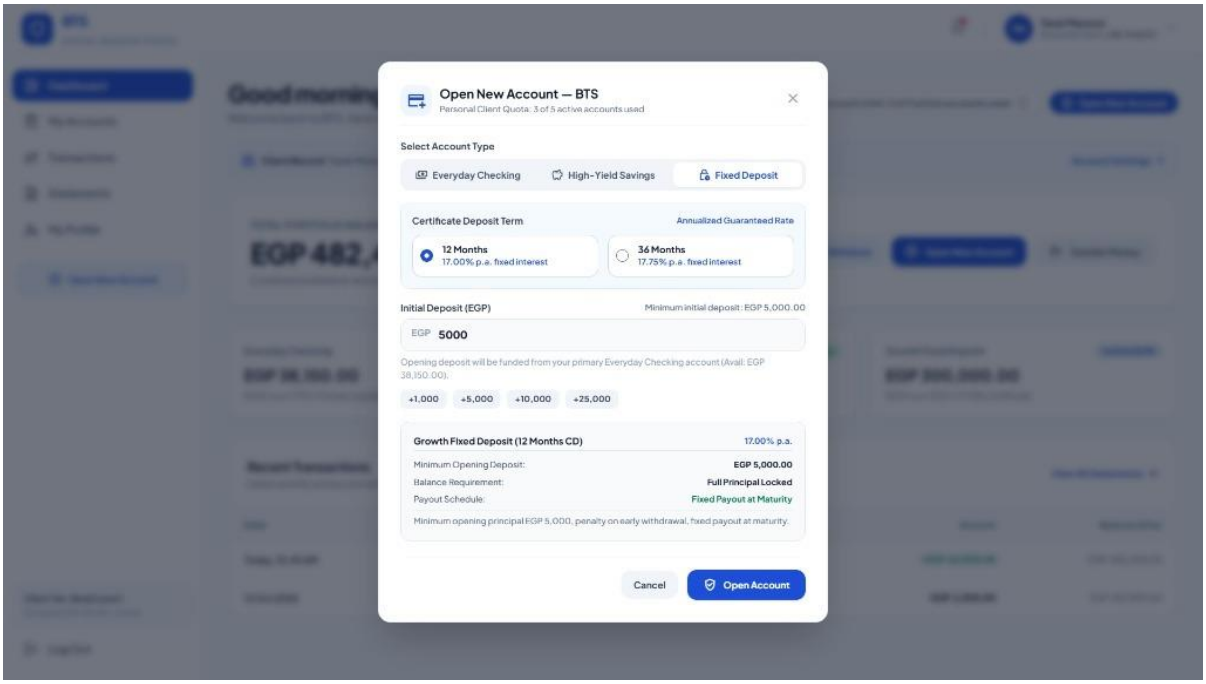


Figure 4.6 — Open New Account Modal: Fixed Deposit Certificate Option (US-08, ACC-01, BR-11, BR-12)

Open New Account Modal: 5 / 5 Account Quota Limit Reached Alert (US-06..08, ACC-06, BR-22): Displays the domain enforcement alert when a customer already holds the maximum of 5 non-closed accounts (MAX_ACCOUNTS_EXCEEDED), instructing the client to close an eligible zero-balance account first.

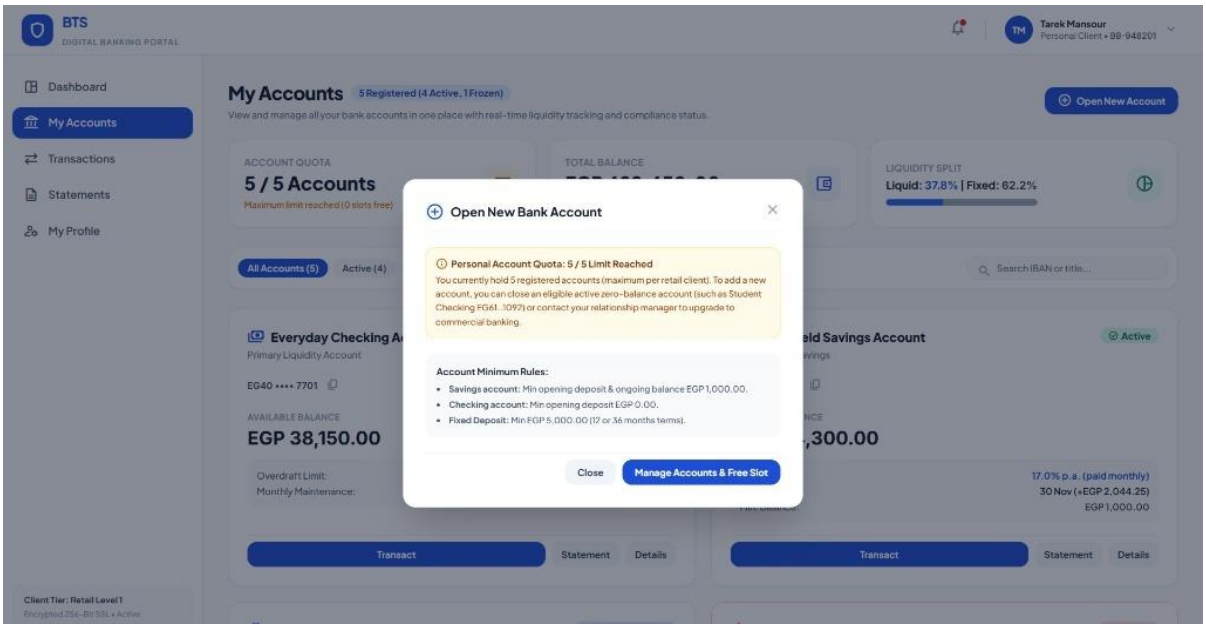


Figure 4.7 — Open New Account Modal: 5 / 5 Account Quota Limit Reached Alert (US-06..08, ACC-06, BR-22)

My Accounts Management Screen (US-06..10, ACC-03, ACC-04, BR-22): Lists all registered customer accounts with quota tracking (3 / 5 Accounts — 2 available slots remaining), liquidity split (Liquid 37.8% | Fixed 62.2%), masked account numbers, and direct Transact / Statement actions.

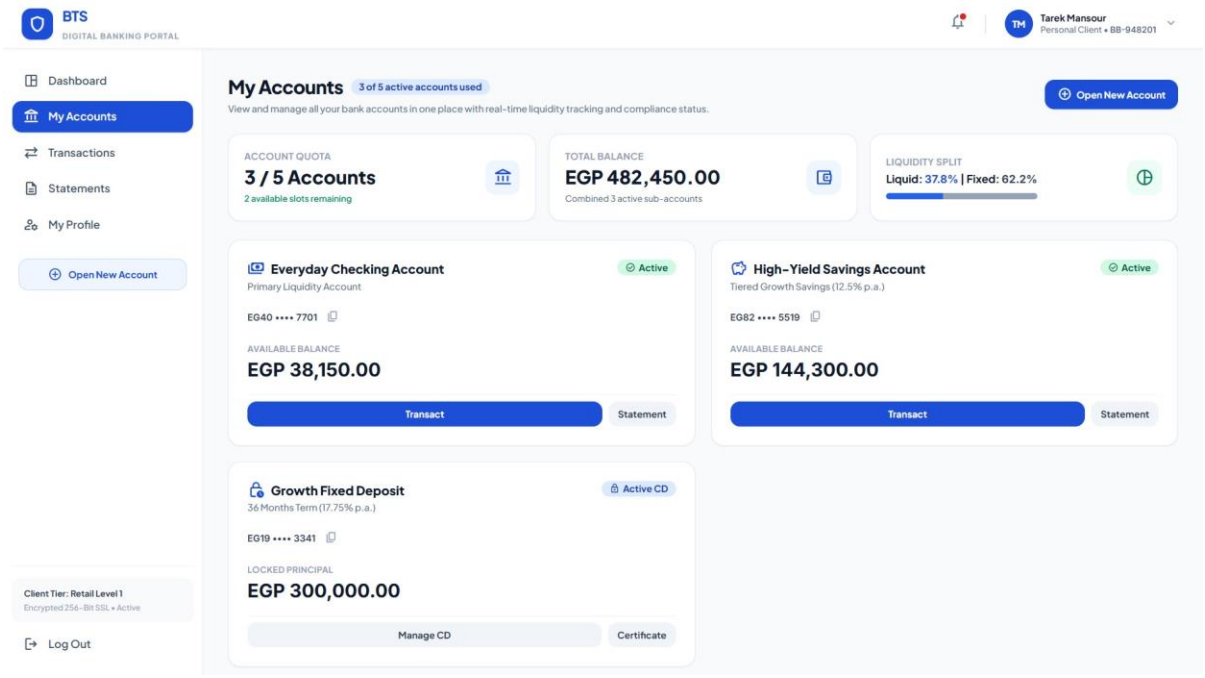


Figure 4.8 — My Accounts Management Screen (US-06..10, ACC-03, ACC-04, BR-22)

Transactions & Domestic Electronic Wire Transfer Screen (US-14, US-15, US-16, TXN-03..09): Displays the wire transfer form with properly bound field labels (Source Account, Recipient IBAN or BTS Account Number, Recipient Full Name, Transfer Type/Network, Transfer Amount EGP, Transfer Description), field-level validation banner, Daily Quota & Limits card, and Continue to Review & Authorize button.

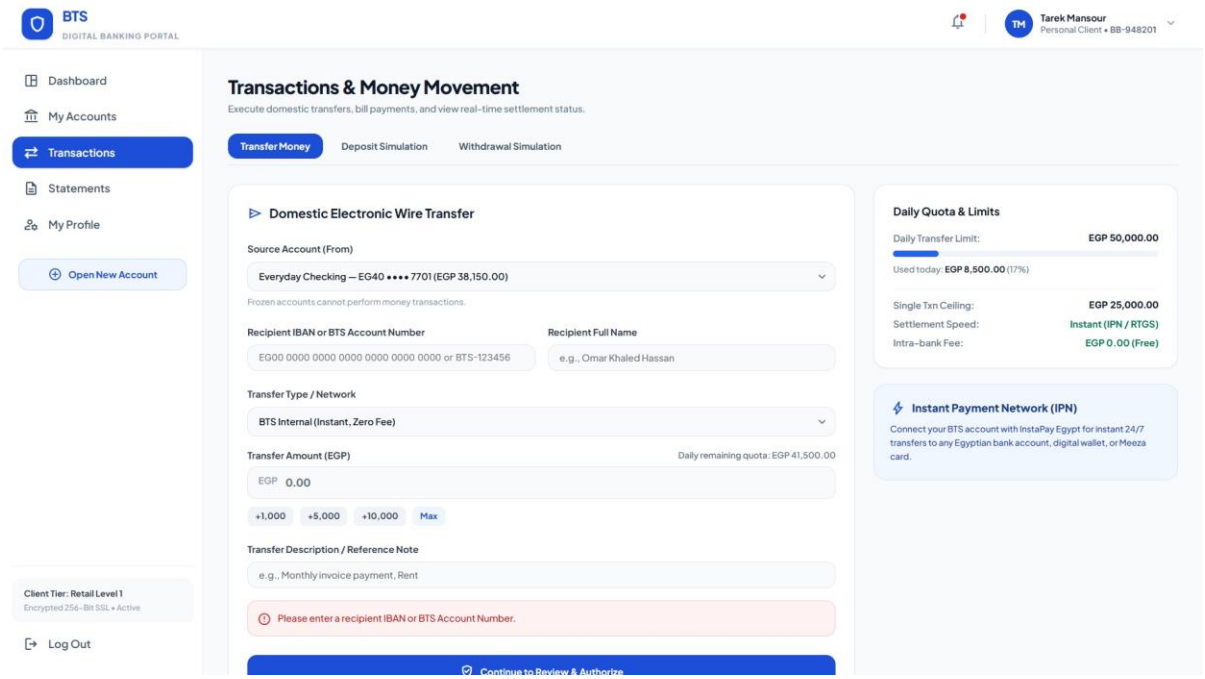


Figure 4.9 — Transactions & Domestic Electronic Wire Transfer Screen (US-14, US-15, US-16, TXN-03..09)

Quick Deposit Simulation Modal (US-11, TXN-01, BR-02): Interactive modal for executing an instant cash deposit into an eligible ACTIVE Checking or Savings account.

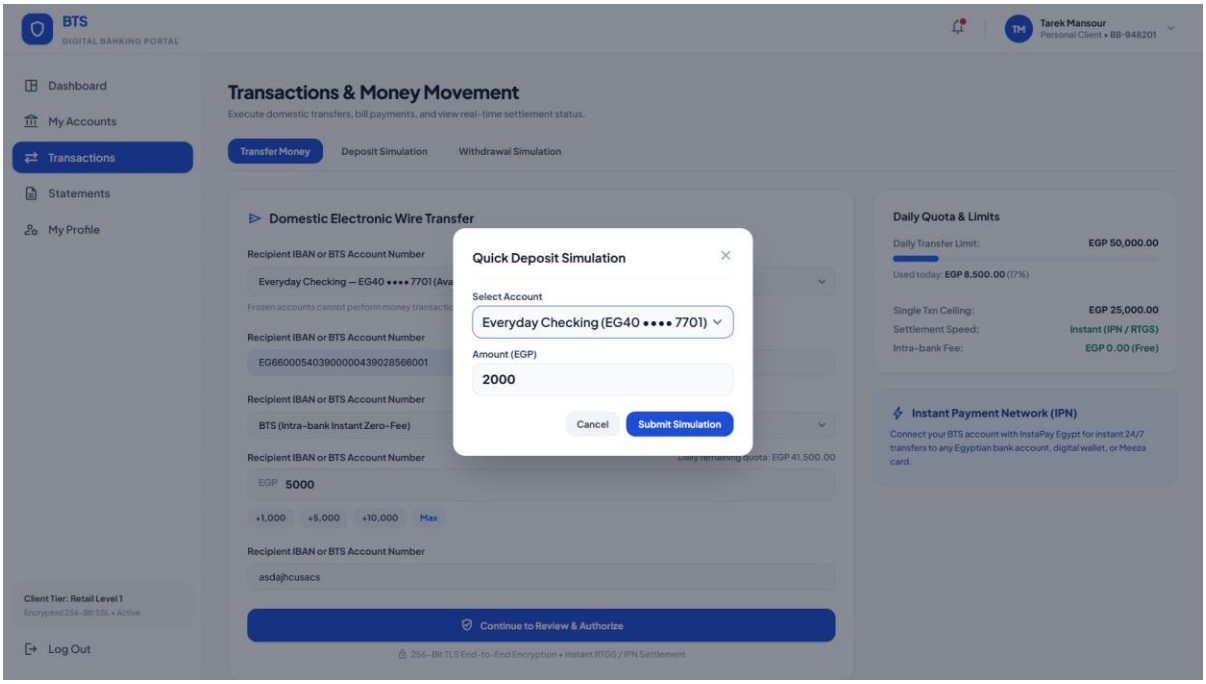


Figure 4.10 — Quick Deposit Simulation Modal (US-11, TXN-01, BR-02)

Quick Withdrawal Simulation Modal (US-12, US-13, TXN-02, BR-07, BR-10): Interactive modal for executing a cash withdrawal subject to Savings minimum balance (1,000.00 EGP), Checking overdraft (-1,000.00 EGP), and daily/monthly withdrawal limits.

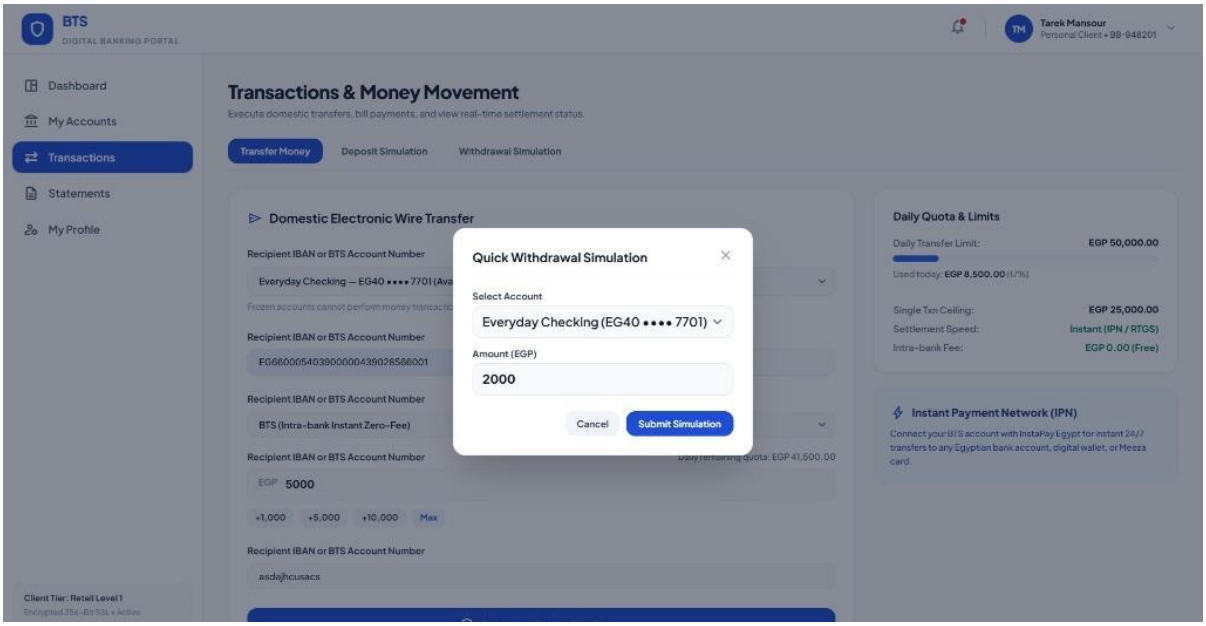


Figure 4.11 — Quick Withdrawal Simulation Modal (US-12, US-13, TXN-02, BR-07, BR-10)

Account Statements, Date/Type Filtering & Safe CSV Export (US-19, US-20, STM-01..03): Displays reconciled inflows/outflows, date range filters (10/01/2026 to 10/25/2026), transaction type selector, newest-first statement ledger with running Balance After, and the Export CSV action.

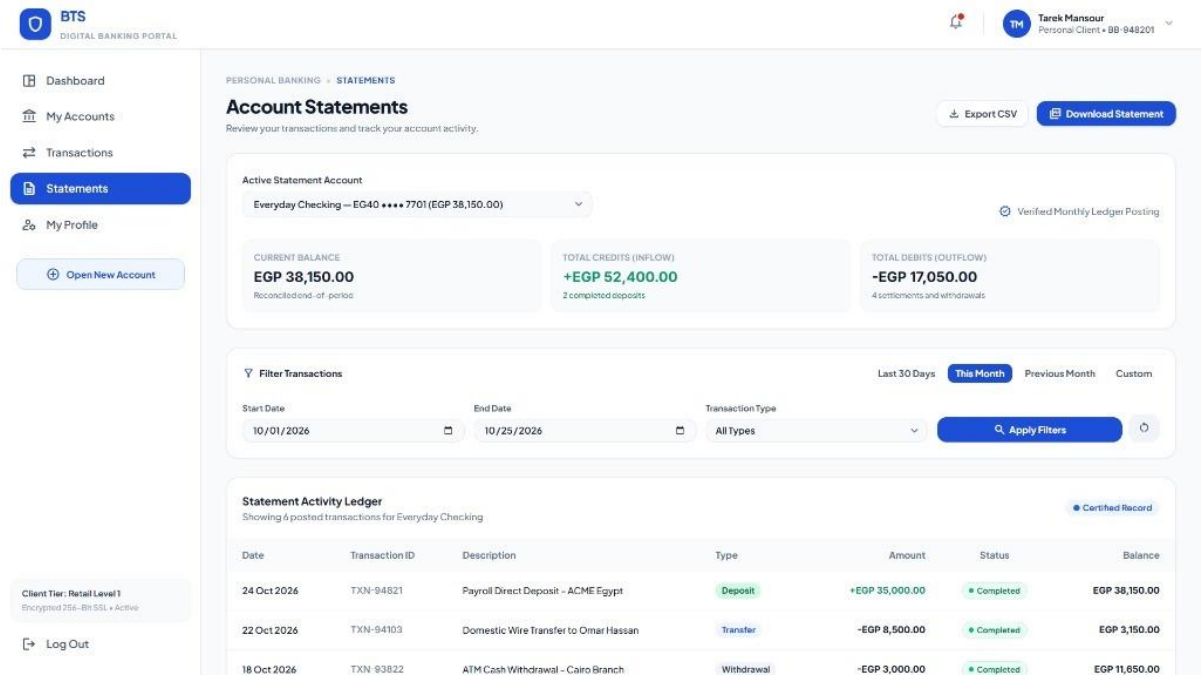


Figure 4.12 — Account Statements, Date/Type Filtering & Safe CSV Export (US-19, US-20, STM-01..03)

My Profile & Security Settings Screen (US-05, CUS-01, CUS-02): Displays editable customer profile fields (Full Legal Name, Registered Mobile Number), read-only Primary Email Address and National ID, and session authentication status.

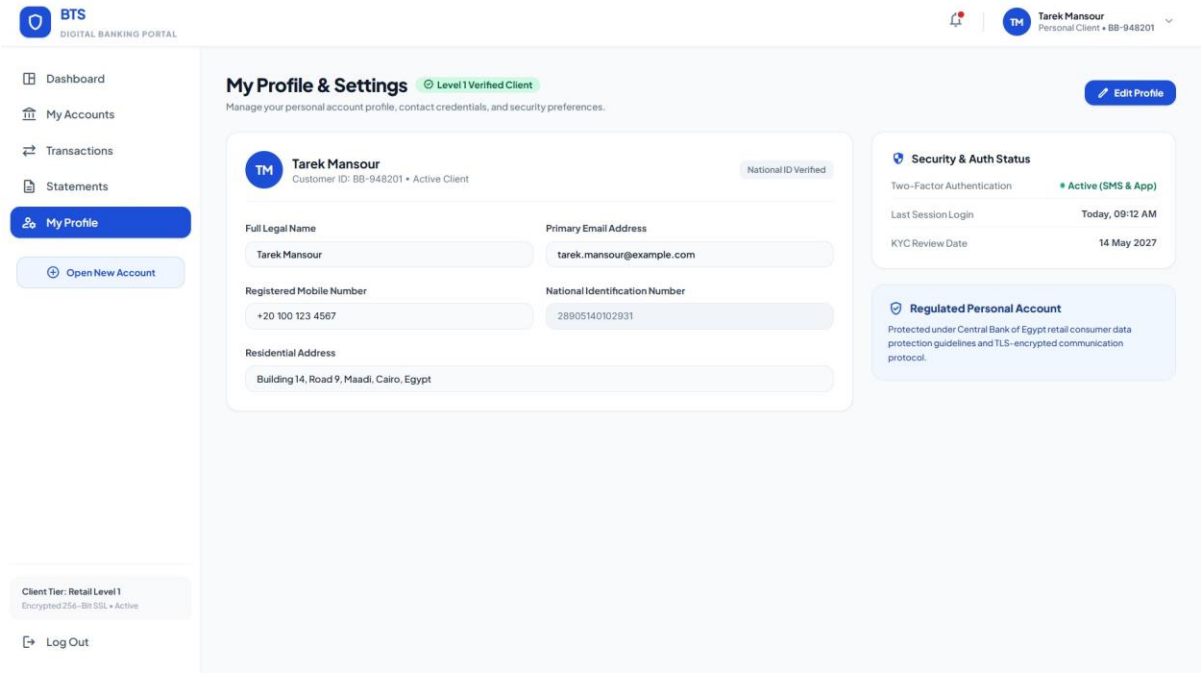


Figure 4.13 — My Profile & Security Settings Screen (US-05, CUS-01, CUS-02)

Standardized HTTP 404 Page Not Found & IDOR Security Guard Screen (US-04, SEC-02, ARCH-02): Uniform error screen rendered when an unauthenticated/unauthorized cross-customer resource is requested (IDOR guard) or a route does not exist, disclosing zero stack-trace details and recording the event in the immutable audit log.

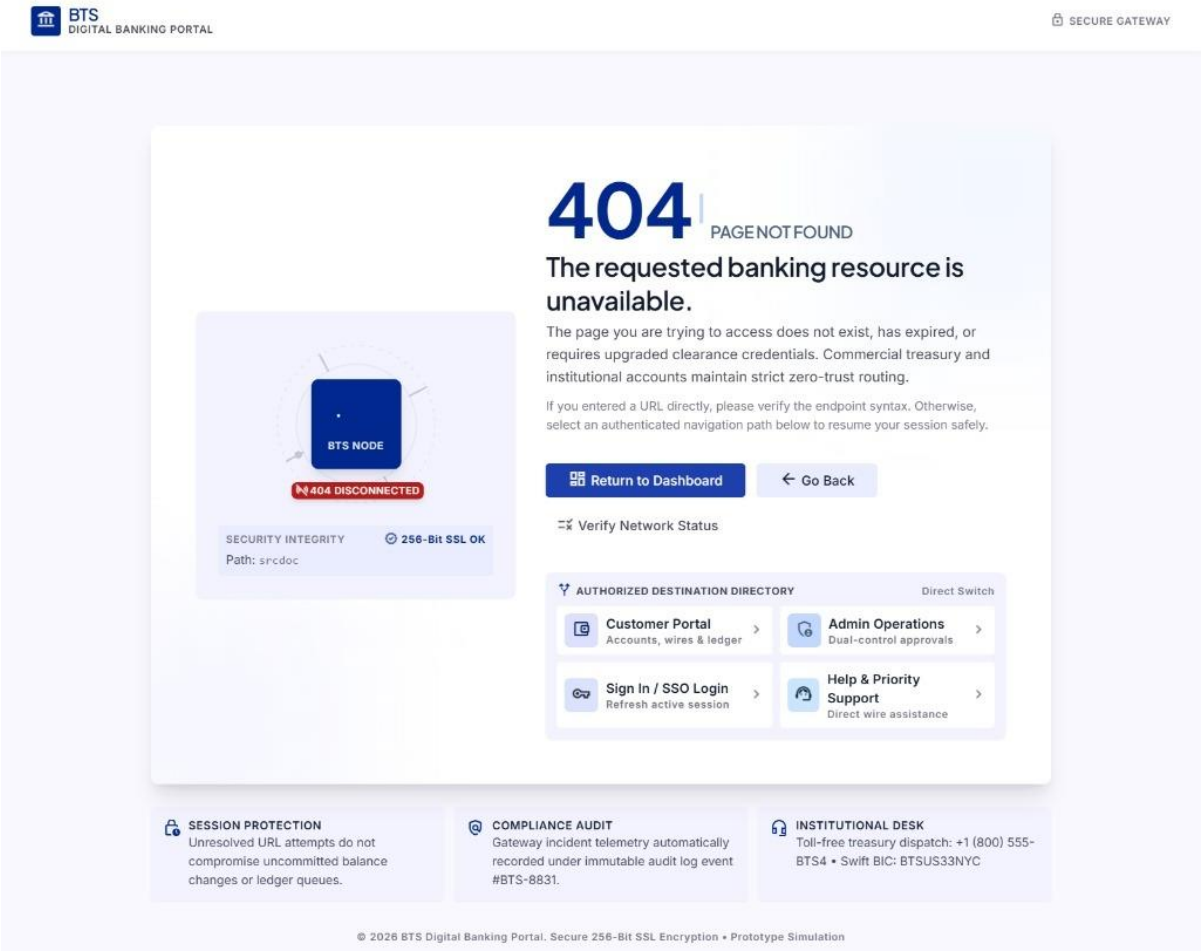


Figure 4.14 — Standardized HTTP 404 Page Not Found & IDOR Security Guard Screen (US-04, SEC-02, ARCH-02)

4.3 Administrative Management Console Screens & Enforcement Modals (UI-02)

Admin Dashboard & Institutional Reserve Metrics (US-21, ADM-01): Displays real-time institutional metrics for Banking Day 25 Oct 2026: Total Reserves (EGP 142,850,000.00 excluding closed accounts), Total Customers (12,480 with 12,461 Verified KYC), Total Accounts (18,920), Transactions Today (1,428), Fees Collected (EGP 42,650.00), Portfolio Composition by Account Type, and Account Integrity Status.

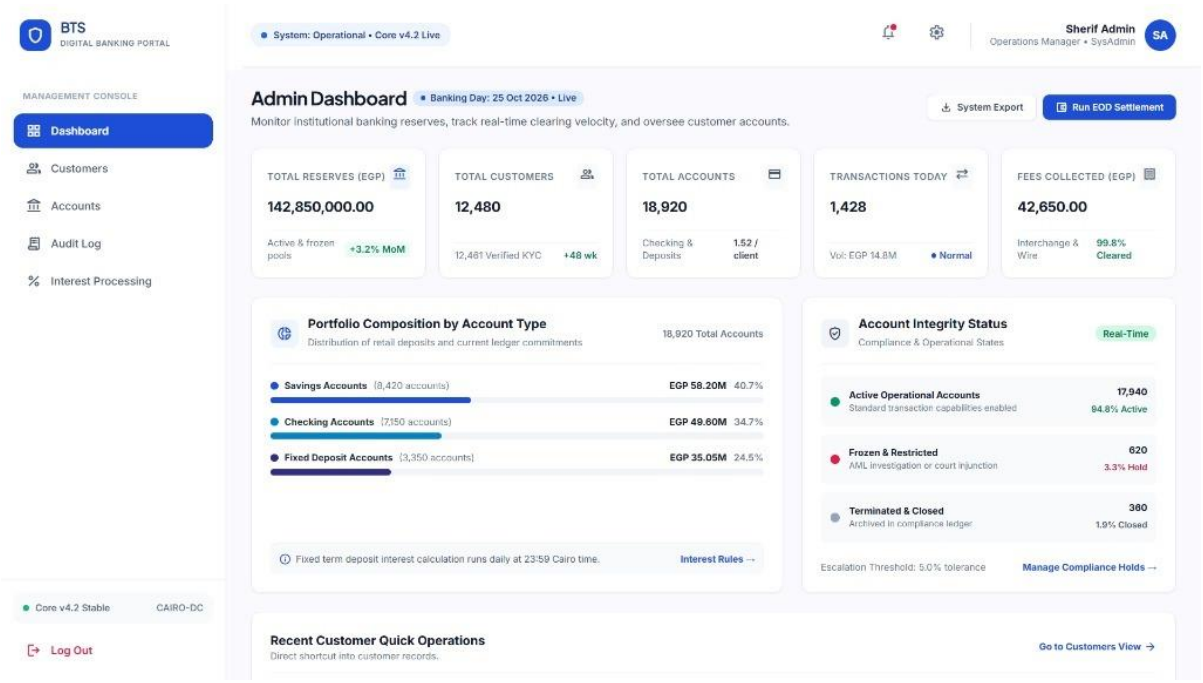


Figure 4.15 — Admin Dashboard & Institutional Reserve Metrics (US-21, ADM-01)

Customer Directory & Search Management Screen (US-21, ADM-02, BR-25): Enables administrators to search customer profiles by name (case-insensitive, trimmed >= 2 characters) and inspect KYC status and linked account counts.

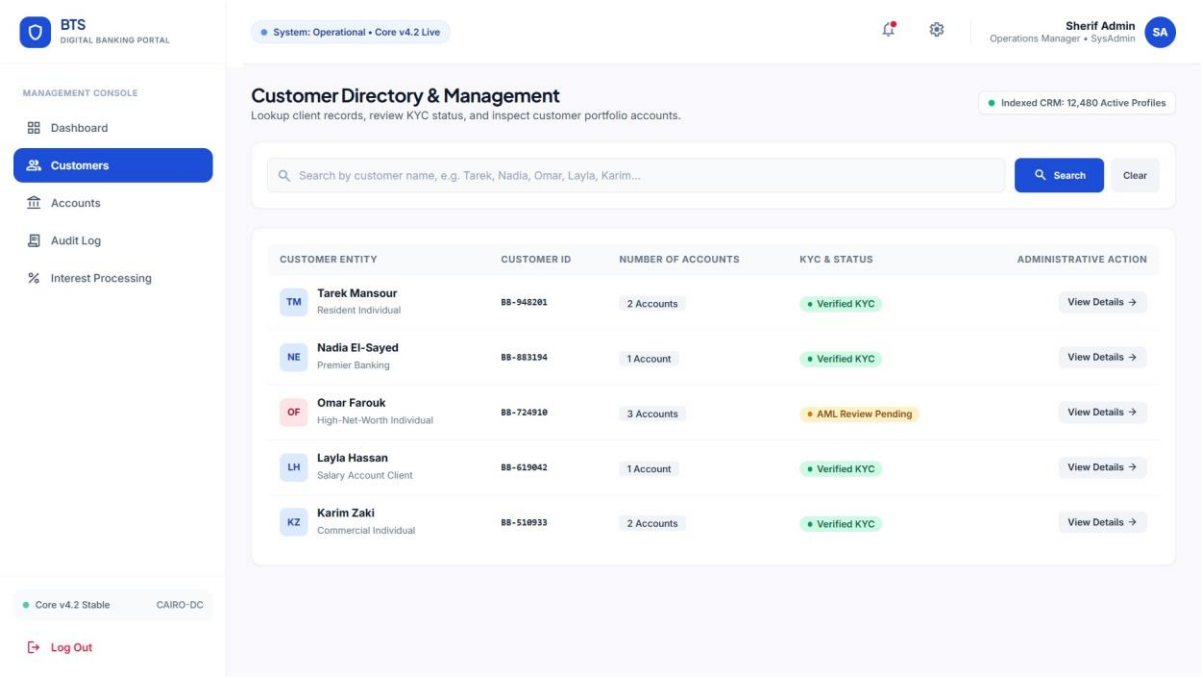


Figure 4.16 — Customer Directory & Search Management Screen (US-21, ADM-02, BR-25)

Accounts Management & Enforcement Screen (US-21, US-22, US-25, ADM-03, ADM-07): Features the prominent yellow Administrative Restriction banner enforcing US-25 ('Administrators are authorized exclusively to inspect ledger records, freeze accounts, or unfreeze accounts. Moving, depositing, withdrawing, or transferring funds on behalf of clients is strictly prohibited'), multi-criteria filters, and Freeze/Unfreeze actions.

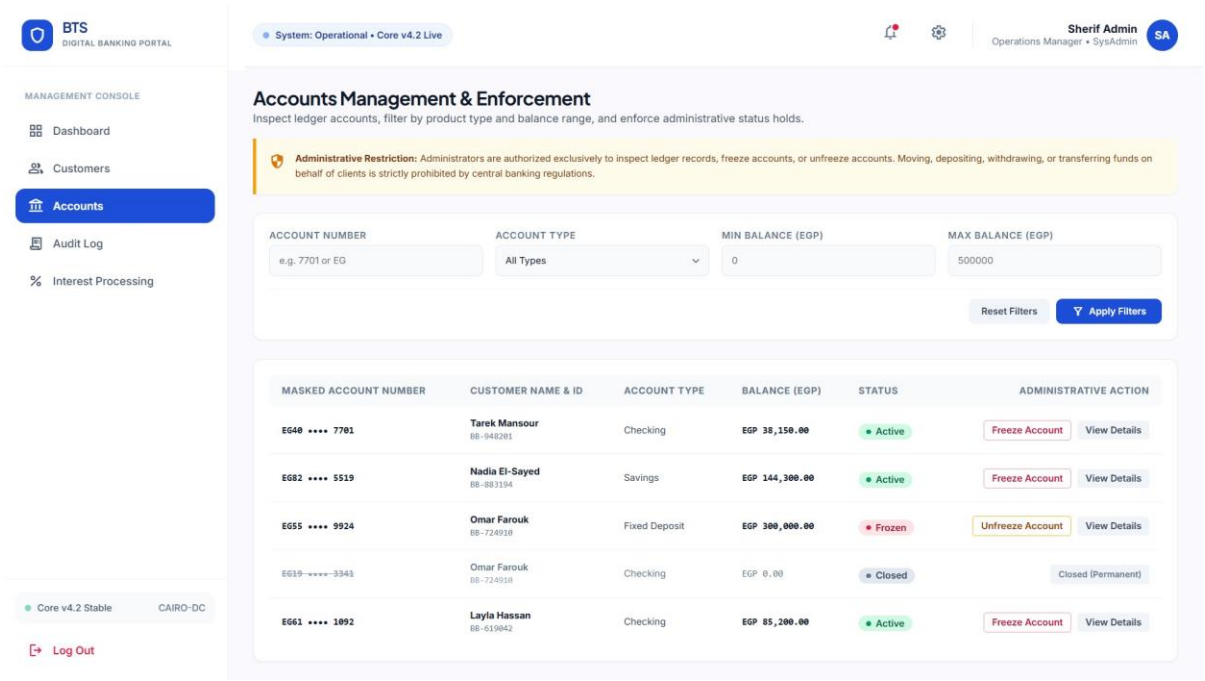


Figure 4.17 — Accounts Management & Enforcement Screen (US-21, US-22, US-25, ADM-03, ADM-07)

Confirm Account Restriction (Freeze) Modal with Mandatory Reason (US-22, ACC-05, BR-20): Supervisory modal requiring a mandatory non-empty Administrative Justification ('Regulatory compliance hold per inquiry #901') before transitioning an ACTIVE account to FROZEN.

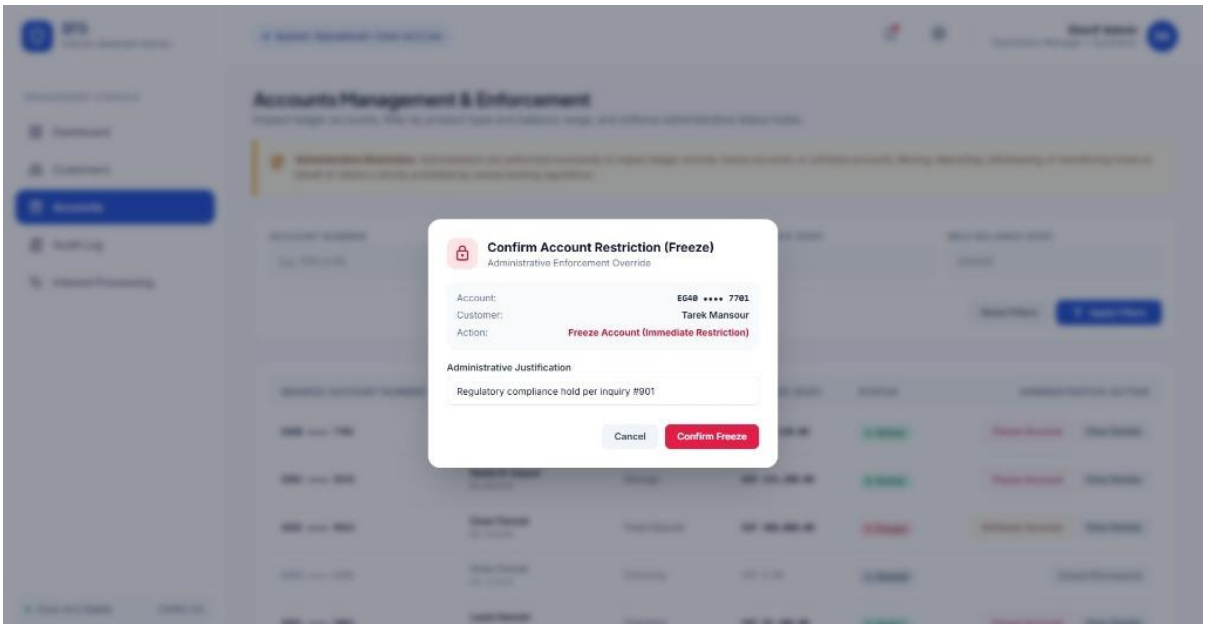


Figure 4.18 — Confirm Account Restriction (Freeze) Modal with Mandatory Reason (US-22, ACC-05, BR-20)

Account Frozen Confirmation Toast & Updated Status State (US-22, BR-20): Displays the immediate confirmation banner ('Account EG40 •••• 7701 has been successfully FROZEN') and updates the account row status badge to Frozen with an Unfreeze Account action.

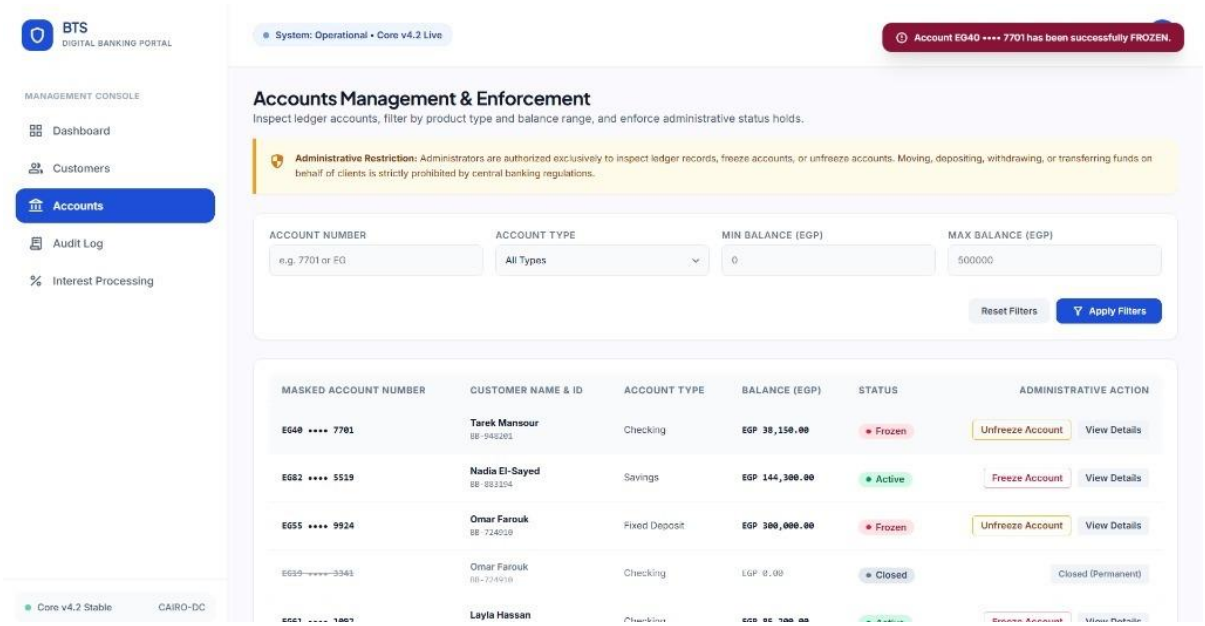


Figure 4.19 — Account Frozen Confirmation Toast & Updated Status State (US-22, BR-20)

Confirm Account Unfreeze Modal with Mandatory Reason (US-22, ACC-05, BR-20): Supervisory modal requiring a mandatory Administrative Justification before restoring a FROZEN account back to ACTIVE operational status.

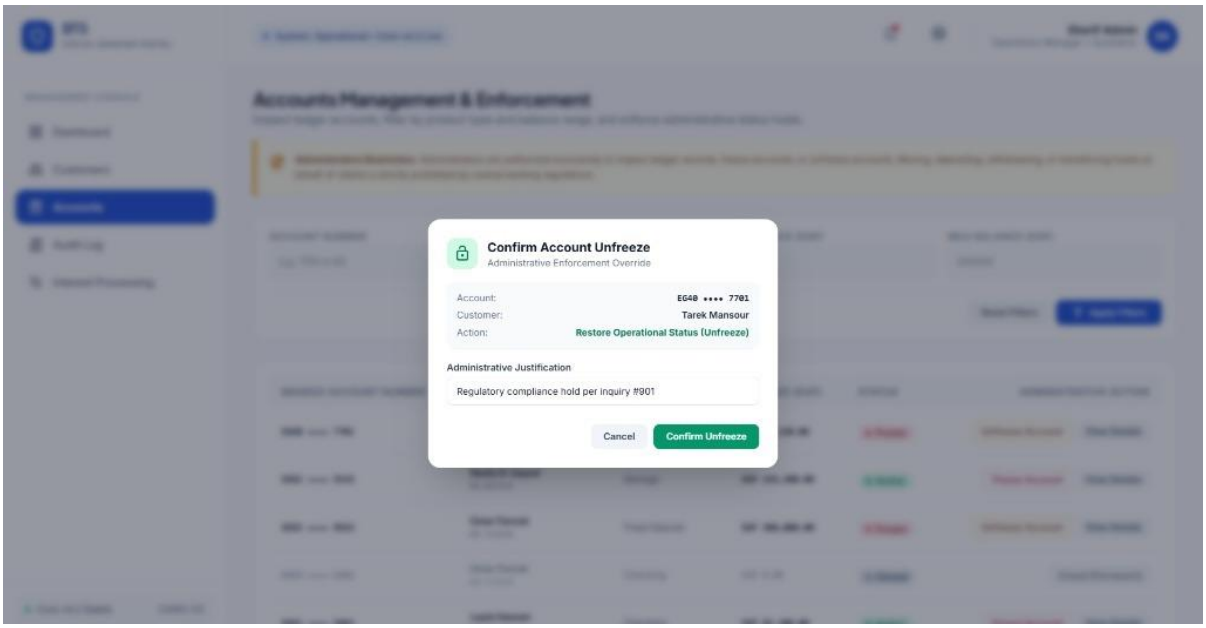


Figure 4.20 — Confirm Account Unfreeze Modal with Mandatory Reason (US-22, ACC-05, BR-20)

Administrative Audit Trail Viewer (US-24, US-25, ADM-05, AUD-01, AUD-02, SEC-11): Displays the immutable, newest-first security and supervisory audit log with filters for Date Range, Admin User, and Action Type, showing Cairo timestamps, actors, actions, masked targets, outcomes, and zero sensitive credentials.

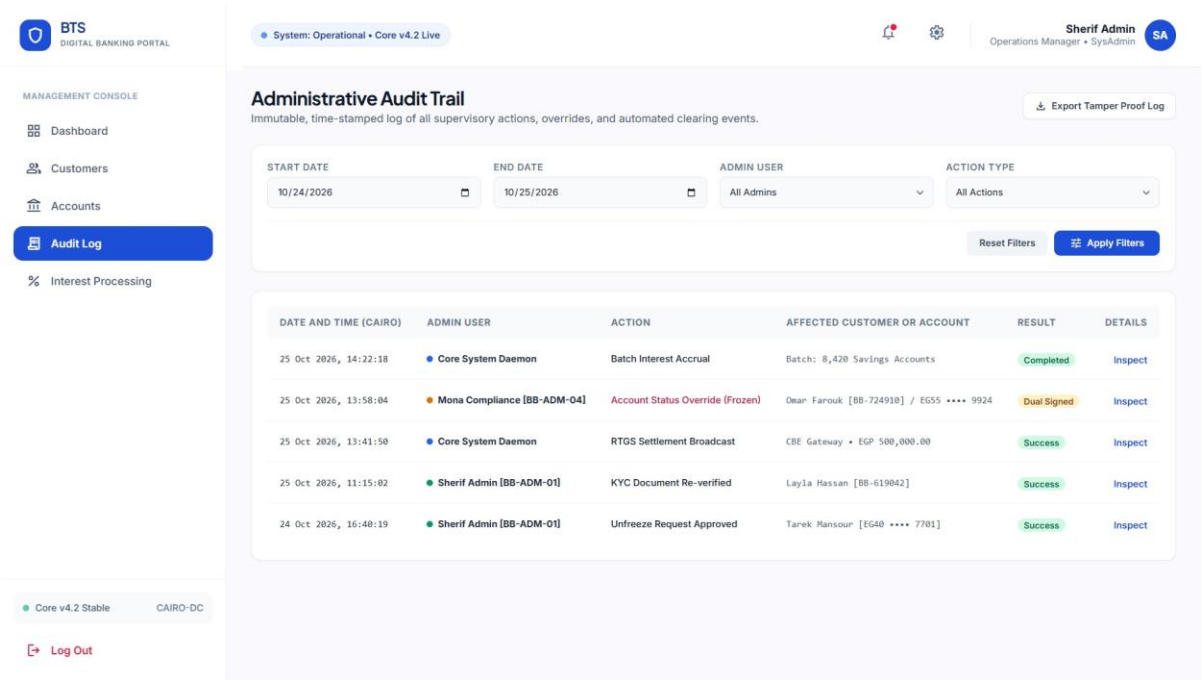


Figure 4.21 — Administrative Audit Trail Viewer (US-24, US-25, ADM-05, AUD-01, AUD-02, SEC-11)

Monthly Interest Calculation & Accrual Engine Screen (US-17, US-18, US-23, JOB-01, JOB-02, ADM-06): Displays last and next scheduled interest runs, engine status (Ready / Idle), Central Bank Regulatory Interest Framework rules (Savings: 17.0% p.a., Fixed Deposit: 17.0% - 17.75% p.a., Checking: 0.0% p.a.), and the Monthly Interest Processing bar with the manual Run Monthly Interest trigger button.

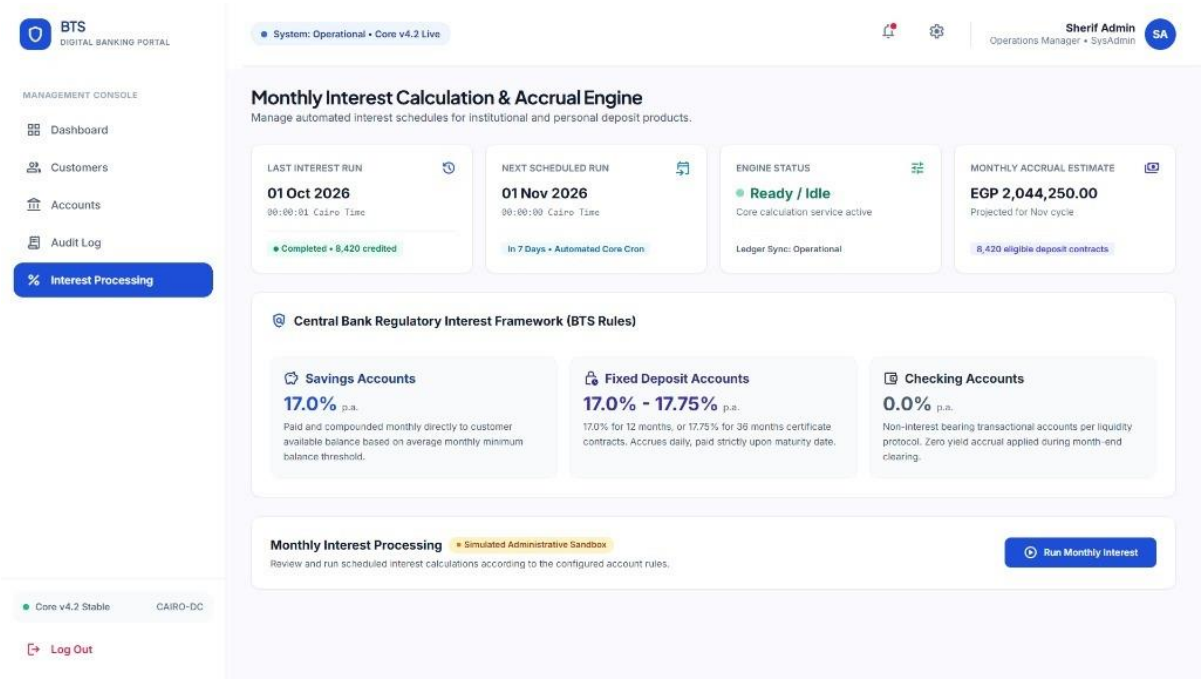


Figure 4.22 — Monthly Interest Calculation & Accrual Engine Screen (US-17, US-18, US-23, JOB-01, JOB-02, ADM-06)

PART 5 — SYSTEM INTEGRATION, MASTER TEST PLAN (69 TEST CASES), BIDIRECTIONAL RTM & USER ACCEPTANCE TESTING (UAT)

Module Lead & Author: Somia Rashad | Banking Transaction System (BTS — Biscuit Bank Team)

5.1 System Integration Architecture, WAL Ledger Flow & Scenarios

Integration testing verifies that the layers and services of the Banking Transaction System cooperate to deliver the specified banking workflows: registration and login, account management, financial transactions, statements, administration, audit logging, and scheduled processing. The system follows the strict layered architecture of NFR-08 (Controller -> Service -> Domain -> Repository). A Spring Security filter chain protects every Controller, and an embedded SQLite database running in Write-Ahead Logging (WAL) mode provides ACID persistence.

5.1.1 Integrated Components and Requirement Links

Component / Interaction	Integration Check	Requirement Traceability
Thymeleaf Web UI → Security Layer → Controllers	Submit registration, login, profile, account-opening, deposit, withdrawal, transfer, statement, and administrative forms; verify the returned pages, the field-level validation messages, and the presence of a valid CSRF token on every state-changing POST.	US-01 to US-16, US-19 to US-24; AUTH-01, AUTH-02; SEC-05; NFR-06
REST API (/api/) → Security Layer → Controllers	Verify HTTP Basic authentication without an HTTP session, request validation, JSON payloads, HTTP status codes, and the error codes of the Error Code Catalogue (§6.1); verify the CSRF exemption of /api/.	AUTH-02; TXN-07 to TXN-09; STM-01 to STM-03; SEC-05; NFR-02, NFR-10
Security Layer: Authentication	Verify BCrypt password verification, the generic login failure message, the five-failure lockout for 15 minutes, and session ID rotation on successful login.	AUTH-02, AUTH-05, AUTH-06; SEC-03, SEC-09; BR-24; US-01, US-02
Security Layer: Authorization	Verify deny-by-default routing and server-side CUSTOMER / ADMIN role enforcement on every page and endpoint, including HTTP 403 for administrator deposit, withdrawal, and transfer requests.	AUTH-03; SEC-01; ADM-07; US-04, US-25
Security Layer: Session Management	Verify the 15-minute idle expiry, immediate invalidation on logout, and the HttpOnly, SameSite=Lax, and Secure cookie attributes.	AUTH-07; SEC-06; US-03
Security Layer: CSRF Protection and Security Headers	Verify rejection of web form POST requests without a valid synchronizer token, and the presence of X-Content-Type-Options, X-Frame-Options, Cache-Control, and Content-Security-Policy headers.	SEC-05, SEC-07
Controllers → Services	Verify Jakarta Bean Validation of incoming DTOs, validation of the 12-digit Luhn account number before any database query, and delegation to the correct service.	SEC-04; ACC-07; BR-23; TXN-07
Services: Ownership Validation	Verify that a customer's request for another customer's account, statement, or transaction returns HTTP 404 ACCOUNT_NOT_FOUND, identical to the response for a non-existent account, in the Web UI and the REST API.	AUTH-04; SEC-01, SEC-02; US-04
Services → Domain (business rules)	Verify enforcement of the monetary, deposit, withdrawal, limit, account-type, Fixed Deposit, account-status, and transfer-fee rules before any state change.	BR-01 to BR-29; ACC-01 to ACC-07; TXN-01 to TXN-03
Services: Idempotency-Key Store and Injected Clock	Verify that a repeated POST with the same Idempotency-Key within 24 hours returns the original response, and that lockout, session, limit, interest, and maturity logic reads time only from the injected Clock.	TXN-08; BR-19; NFR-05; US-16

Domain → Repositories → SQLite	Verify persistence through the piaster AttributeConverter (BigDecimal scale 2 with HALF_UP to BIGINT piasters) and the absence of floating-point storage.	NFR-01; BR-01; BR-17
Ledger Flow	Verify that balance updates and append-only ledger rows (DEPOSIT, WITHDRAWAL, TRANSFER_OUT, TRANSFER_IN, FEE, INTEREST), each carrying balance_after and a reference shared across the legs of one operation, commit or roll back together in one database transaction.	TXN-04, TXN-05; BR-16 to BR-18, BR-27, BR-29; NFR-04; US-11 to US-15
Audit Logging	Verify that security, financial, and administrative events originating in the Security Layer and the Services are recorded with the AUD-02 fields, and that passwords, hashes, session tokens, and unmasked account numbers never reach the audit log or the application logs.	AUD-01, AUD-02; SEC-11; NFR-11; US-22, US-24
Scheduler Service → Interest and Maturity Services → Ledger Flow	Verify monthly Savings interest once per account per calendar month, Fixed Deposit maturity interest exactly once, and the idempotent manual trigger executed by an administrator with an audit entry.	JOB-01, JOB-02; ADM-06; BR-08, BR-12, BR-15; US-17, US-18, US-23
SQLite WAL Configuration	Verify WAL mode, the 5,000 ms busy timeout, BEGIN IMMEDIATE write locks, and the single-connection HikariCP pool under parallel requests and forced exceptions.	NFR-03; TXN-05, TXN-06
Statement Service → Ledger	Verify newest-first ordering, balance_after display, pagination (default 10, maximum 100 rows), date and type filtering, and CSV export against the ledger rows.	STM-01 to STM-03; BR-17; US-19, US-20
Admin Services → Account and Customer Data	Verify dashboard aggregates, customer search, account search, the richest-customer report, freeze and unfreeze with a mandatory reason, the audit viewer, and the denial of administrator financial operations.	ADM-01 to ADM-07; ACC-05; US-21 to US-25
Profile and Account Services	Verify profile update, dashboard totals, account opening and closure, and generation of the unique 12-digit Luhn account number.	CUS-01 to CUS-03; ACC-01 to ACC-04, ACC-06; BR-20 to BR-23; US-05 to US-10

5.1.2 Integration Architecture Diagram & Execution Flow

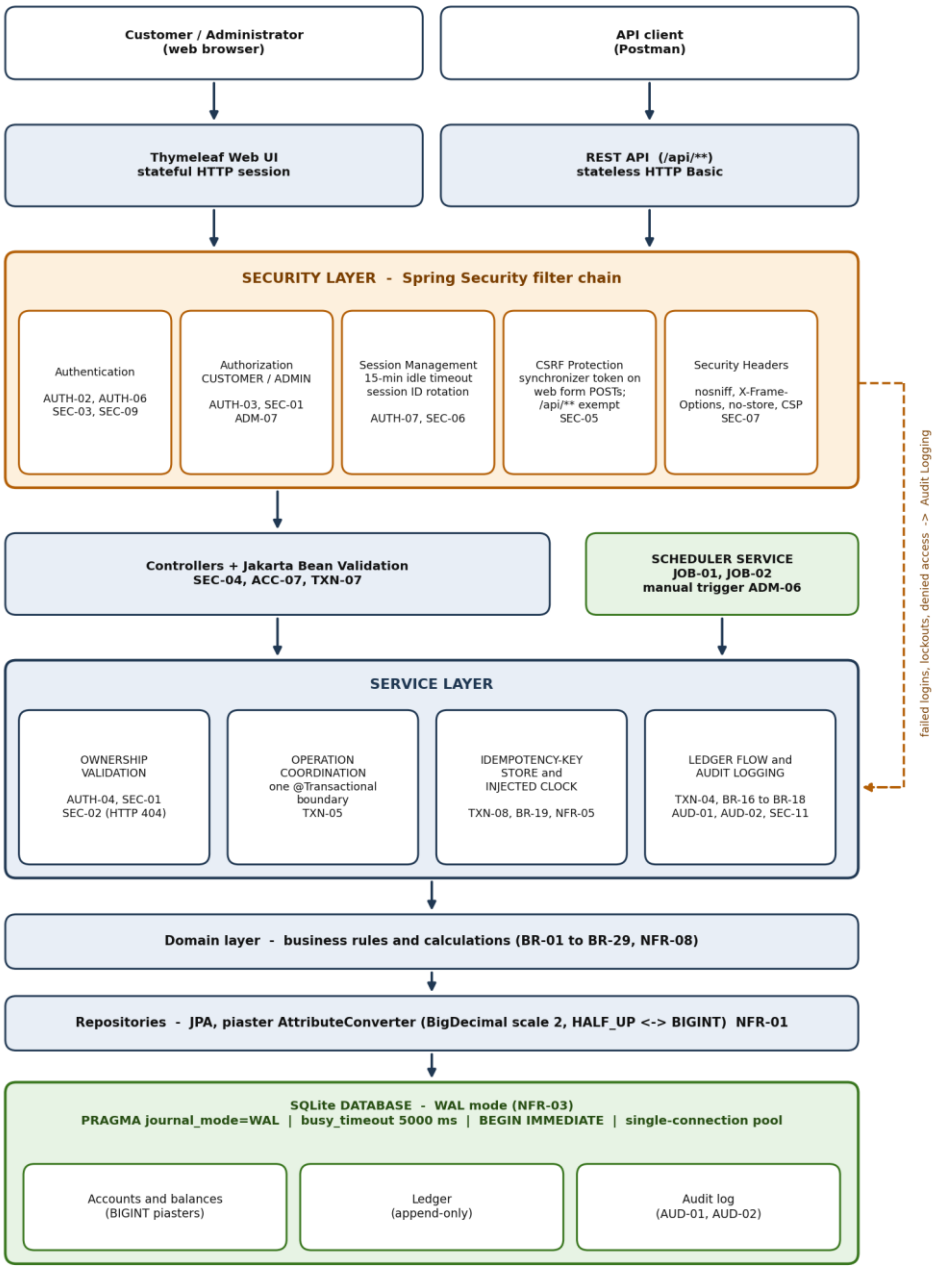


Figure 5.1 — Layered Integration Architecture & Security Pipeline of the Banking Transaction System (BTS)

5.1.3 Integration Test Scenarios (IT-01 to IT-13)

ID	Flow Under Test	Verification	Traceability
IT-01	Registration: Web UI → Security Layer (CSRF) → Controller (Bean Validation) → Authentication and Customer services → Repositories → SQLite	The login credential and the customer profile are stored in one transaction; a duplicate email in any letter case stores nothing; the register event is audited.	US-01; AUTH-01, AUTH-05; CUS-02; BR-24; SEC-05; AUD-01
IT-02	Login, lockout, and session: Security Layer (Authentication, Session Management) → Audit Logging	Session ID changes at login; five failures lock the account for 15 minutes with a generic message; idle expiry after 15 minutes; failures and lockout are audited.	US-02, US-03; AUTH-02, AUTH-06, AUTH-07; SEC-03, SEC-06, SEC-09; AUD-01
IT-03	Ownership: Security Layer → Controller	A customer's request for another customer's account,	US-04; AUTH-04; SEC-01,

	→ Service (Ownership Validation) → Repository	statement, or transaction returns HTTP 404 ACCOUNT_NOT_FOUND, identical to a non-existent account, through the Web UI and the REST API; the attempt is audited.	SEC-02; SEC-11
IT-04	Inter-customer transfer: Web UI confirmation and REST quote → Service → Domain (fee) → Ledger Flow → SQLite → Audit Logging	The confirmation shows the fee and total debit; execution commits both balances and the TRANSFER_OUT, TRANSFER_IN, and FEE rows with one reference in one transaction; the event is audited.	US-15, US-16; TXN-03, TXN-04, TXN-05, TXN-09; BR-26, BR-28, BR-29; AUD-01
IT-05	Idempotent retry: Controller → Service → Idempotency-Key store → Ledger Flow	A second POST with the same Idempotency-Key within 24 hours returns the original response and writes no ledger rows.	US-16; TXN-08; BR-19
IT-06	Rollback and concurrency: Services → Ledger Flow → SQLite WAL	A forced exception rolls back all balance and ledger changes; parallel requests on one account produce no lost update, no limit bypass, and no SQLITE_BUSY error.	NFR-03; TXN-05, TXN-06; BR-06, BR-07, BR-29
IT-07	Savings interest: Scheduler Service (or admin manual trigger) → Interest service → Ledger Flow → Audit Logging	ACTIVE Savings accounts receive one INTEREST row per calendar month; a repeated run in the same month credits nothing; a manual trigger writes an audit entry.	US-18, US-23; JOB-01; ADM-06; BR-08; AUD-01
IT-08	Fixed Deposit maturity: Scheduler Service → Maturity service → Ledger Flow	Term interest is posted exactly once on or after the maturity date and the deposit is marked matured for full withdrawal.	US-17; JOB-02; BR-12, BR-14, BR-15
IT-09	Freeze and unfreeze: Admin Controller → Account service → Repositories → Audit Logging	The status changes only with a non-empty reason of at most 255 characters; deposits, withdrawals, and transfers on a FROZEN account return ACCOUNT_FROZEN; each action is audited.	US-22; ACC-05; BR-20; AUD-01
IT-10	Separation of duties: Security Layer (Authorization) → Money endpoints	An ADMIN request for a deposit, withdrawal, or transfer returns HTTP 403 and changes no data.	US-04, US-25; ADM-07; AUTH-03; SEC-01
IT-11	Statement: Statement service → Ledger → SQLite	Ordering, balance_after, pagination, filters, and the CSV export agree with the ledger rows.	US-19, US-20; STM-01 to STM-03; BR-17
IT-12	Audit viewer: Admin Controller → Audit Logging → SQLite	Entries filtered by date range, actor, and action type contain the AUD-02 fields and never contain passwords, hashes, or session tokens.	US-24; ADM-05; AUD-01, AUD-02; SEC-11
IT-13	Admin dashboard and search: Admin services → Account and customer data → SQLite	Dashboard figures, customer search, account search, and the richest-customer report equal the corresponding database aggregates.	US-21, US-25; ADM-01 to ADM-04

5.2 Master Test Plan, 69 Requirement-Based Test Cases & RTM

The Master Test Plan uses structured black-box and white-box test design techniques—Equivalence Partitioning (EP), Boundary Value Analysis (BVA), and Decision Tables (QA-01)—alongside automated verification methods (JUnit 5, JaCoCo >= 90% domain coverage, Spring Security MockMvc, Postman/Newman < 500 ms P95 latency assertions, Selenium 4 Page Object Model on Chrome, OWASP Dependency-Check, and SonarLint/SpotBugs).

5.2.1 Defined Test Types & Verification Basis

Test Type	What Is Tested (Requirement-Specific)	Basis / Tool in Requirement Gathering
Unit Testing	Monetary precision and HALF_UP rounding; amount, deposit, withdrawal, and limit validation; Savings minimum balance; Checking overdraft; Fixed Deposit rules; transfer-fee calculation; interest calculation; account-number generation and Luhn validation; Clock-driven lockout, limit, and maturity logic.	NFR-01, NFR-05; BR-01 to BR-15, BR-23, BR-26 to BR-29; ACC-02, ACC-07. JUnit 5 & JaCoCo (>= 90% domain coverage) with Clock mocking.
Integration Testing	Controller → Service → Domain → Repository → SQLite paths;	NFR-03, NFR-04; TXN-01 to TXN-09; AUD-

	ownership validation; ledger flow; transaction commit and rollback; audit events; session and lockout behaviour; scheduled jobs (scenarios IT-01 to IT-13).	01, AUD-02; JOB-01, JOB-02. Spring Boot Test, MockMvc & JUnit 5 with embedded SQLite WAL.
API Testing	Request validation; JSON responses; HTTP status and error codes of §6.1; HTTP Basic authentication; role and ownership enforcement; fee quote; Idempotency-Key behaviour; statement endpoints; endpoint latency.	AUTH-02, AUTH-03; TXN-07 to TXN-09; STM-01 to STM-03; SEC-02; NFR-02. Postman collection runner.
UI / Functional Testing	Registration, login, logout, profile, dashboard, account opening and closure, deposit, withdrawal, transfer with confirmation screen, statements and CSV export, admin dashboard, search, freeze, audit viewer, and manual job trigger.	US-01 to US-25; CUS, ACC, TXN, STM, ADM requirements. Selenium 4 WebDriver (Page Object Model - POM) on Chrome with frozen element IDs.
Security Testing	Deny-by-default access control; IDOR with HTTP 404; role separation; BCrypt storage, lockout, and session fixation; SQL injection and XSS; CSRF; cookie attributes; security headers; sensitive-data exposure; audit of security events; dependency scan.	SEC-01 to SEC-11; AUTH-03 to AUTH-08; ADM-07; US-02, US-03, US-04, US-25. Spring Security MockMvc, Postman, Selenium 4, OWASP Dependency-Check & SonarLint/SpotBugs.
Database / Data Integrity Testing	BIGINT piaster storage; absence of floating-point types; balances equal ledger sums; balance_after; append-only ledger; unique transaction references; rollback leaves no partial updates.	NFR-01, NFR-03, NFR-04; TXN-04, TXN-05; BR-16 to BR-18, BR-29. JUnit 5, database permission and code review, SonarLint.
Concurrency Testing	Parallel withdrawal and transfer on one account; parallel enforcement of daily and monthly limits; parallel deposits; single-writer WAL behaviour with no lost update, no duplicate ledger posting, and no SQLITE_BUSY error.	NFR-03; TXN-06; BR-05 to BR-07. Automated multi-threaded test TC-C-01.
Performance Testing	REST endpoints respond in under 500 ms at P95 and server-rendered pages load in under 2.0 seconds on a standard developer workstation with seeded SQLite data.	NFR-02 (KPI-05). Postman collection runner latency assertions.
Scheduled-Job Testing	Monthly Savings interest eligibility, formula, rounding, and one posting per account per calendar month; Fixed Deposit maturity interest posted exactly once; idempotent manual trigger.	JOB-01, JOB-02; ADM-06; BR-08, BR-12, BR-15. JUnit 5 with Clock mocking.
Audit Logging Testing	Registration, login success and failure, lockout, account open, close, freeze, and unfreeze, deposits, withdrawals, successful and failed transfers, unauthorized access attempts, and manual job triggers are recorded with the AUD-02 fields; passwords, hashes, and session tokens are never recorded.	AUD-01, AUD-02; SEC-11; NFR-11; US-22, US-24. Integration tests and log inspection.
Compatibility Testing	Full functional and visual behaviour on the latest Google Chrome (automated); smoke tests on Mozilla Firefox and Microsoft Edge.	NFR-07. Selenium WebDriver suite and manual cross-browser smoke checklist.
Usability and Accessibility Testing	Field-level validation messages, fixed DOM IDs for banners, responsive layout at 1366 px and 375 px, label bindings, keyboard navigation, and WCAG AA colour contrast.	NFR-06, NFR-12. Manual UI testing, Selenium assertions, and manual accessibility checklist.
Static Analysis and Maintainability Review	Layered architecture, absence of business logic in controllers and templates, time obtained only from the injected Clock, absence of floating-point money types, absence of committed secrets, and peer-reviewed pull requests.	NFR-01, NFR-05, NFR-08; SEC-08. SonarLint, SpotBugs, and the GitHub pull-request review checklist.
Portability and Documentation Verification	Fresh-clone build and start with mvn spring-boot:run; generated OpenAPI / Swagger UI; README setup commands, profiles, and demo credentials.	NFR-09, NFR-10. Fresh-clone verification on team laptops and technical review.
User Acceptance Testing (UAT)	Fourteen end-to-end customer and administrator journeys with explicit test data covering every user story (Section 3).	US-01 to US-25 and their linked requirements and rules.

5.2.2 Requirement-Based Test Cases (69 Test Cases across 7 Suites)

Suite 5.2.2.1 Authentication and Session

Test ID	Type	Traceability	Test Scenario / Test Data	Expected Result

TC-REG-01	UI / API	US-01, AUTH-01, CUS-02, BR-24, AUD-01	Register with full name "Mona Hassan", email "Mona.Hassan@example.com", phone "+201001234567", password "Secure1Pass". Register again with email "mona.hassan@example.com". Register a third user with the phone omitted.	The first registration atomically creates the login credential and the customer profile, and the user logs in. The second is rejected with DUPLICATE_EMAIL (HTTP 409) and stores nothing. Registration without a phone succeeds (AUTH-01). A register event is written to the audit log.
TC-REG-02	UI / Unit	US-01, AUTH-05, CUS-02	Submit passwords of 7, 8, 64, and 65 characters, and passwords lacking an uppercase letter, a lowercase letter, or a digit. Submit full names of 1, 2, 50, and 51 characters and a name containing a digit. Submit an email without "@" and an email longer than 100 characters. Submit phone numbers of 9, 10, 15, and 16 digits.	Passwords of 8 and 64 characters, names of 2 and 50 characters, and phones of 10 and 15 digits are accepted. Every other value is rejected with a field-level message beside the field and no record is created.
TC-AUTH-01	Integration (Clock)	US-02, AUTH-06, SEC-03, SEC-09, BR-24, AUD-01, AUD-02, NFR-05	For Customer C submit five consecutive wrong passwords; call the time of the fifth failure t. At t + 14 min 59 s submit the correct password. At t + 15 min 01 s submit the correct password.	The attempt with the correct password at t + 14 min 59 s is refused with the generic message 'Invalid email or password' (error code ACCOUNT_LOCKED, BR-24). A lockout entry with actor, timestamp, and client IP is written to the audit log. The login at t + 15 min 01 s succeeds.
TC-AUTH-02	UI / API	US-02, US-03, AUTH-02, AUTH-03, SEC-03	Log in with valid credentials and record the session ID before and after. Log in with a wrong password and with an unregistered email. Log out, then request a protected page with the old session cookie.	The valid login redirects to the customer dashboard and the session ID differs from the pre-login ID. Both failures display only 'Invalid email or password'. After logout the old cookie is rejected and the login page is shown.
TC-AUTH-03	API	US-02, AUTH-02, AUTH-03	Call an endpoint under /api/ with valid HTTP Basic credentials, with invalid credentials, and with no credentials.	Valid credentials return the requested data and no HTTP session is created. Invalid and missing credentials are rejected and return no data.
TC-SESSION-01	Integration (Clock)	US-03, AUTH-07, SEC-06, NFR-05	Log in as Customer A. Advance the injected Clock by 14 minutes and submit a request. Advance the Clock by 15 minutes without any request, then submit a request.	The request after 14 minutes succeeds. The request after 15 minutes of inactivity invalidates the session and redirects to the login page.
TC-AUTH-04	Integration	AUTH-08, SEC-08	Start the application under a profile other than dev or test with the administrator credentials supplied in environment variables, and try the fixed demonstration credentials. Start it under the dev profile and try the demonstration credentials.	Outside the dev and test profiles the administrator account is provisioned from the environment variables and the demonstration credentials are rejected. Under dev, the demonstration credentials exist.

Suite 5.2.2.2 Customer Profile and Accounts

Test ID	Type	Traceability	Test Scenario / Test Data	Expected Result
TC-CUS-01	UI	US-05, CUS-01, CUS-02	Change the full name to "Mona Hassan-Ali" and the phone to "01001234567" and save. Submit the name "M1" and the phone "12345". Attempt to change the email by editing the submitted request.	Valid values persist immediately. Invalid values show field-level messages and are not saved. The email is displayed read-only and remains unchanged.
TC-CUS-02	UI	US-10, CUS-03	Customer with two ACTIVE accounts (balances 1,500.00 and 300.00 EGP), one FROZEN account (200.00 EGP), and one CLOSED account. Open the dashboard.	All four accounts are listed with type, 12-digit number, status, and balance. The total balance is 2,000.00 EGP (non-closed accounts only).
TC-ACC-01	UI / API	US-06, ACC-01, ACC-02, BR-07	Open a Savings account with an opening deposit of 1,000.00 EGP.	The account is created with balance 1,000.00 EGP, status ACTIVE, and a unique 12-digit account number.
TC-ACC-02	Integration	US-06, US-07, US-08,	A customer with five non-closed accounts	The sixth request is rejected with

		ACC-06, BR-22	opens a sixth account. Close one account with balance 0.00, then open an account again.	MAX_ACCOUNTS_EXCEEDED (HTTP 422). After one account is CLOSED, which is not counted, opening succeeds.
TC-ACC-03	Unit / API	US-06, US-07, US-08, ACC-01, BR-01, BR-07, BR-09, BR-11, BR-12	Opening deposits: Savings 999.99; Checking 0.00, 100,000.00, and 100,000.01; Fixed Deposit 4,999.99; Fixed Deposit 5,000.00 with terms of 12 and 36 months; Fixed Deposit 5,000.00 with a 24-month term.	Savings 999.99 → MIN_BALANCE_VIOLATION. Checking 0.00 and 100,000.00 succeed; 100,000.01 → INVALID_OPENING_AMOUNT. Fixed Deposit 4,999.99 → MIN_OPENING_DEPOSIT_VIOLATION. Fixed Deposit 5,000.00 succeeds at 17.00% (12 months) and 17.75% (36 months) with maturity date = opening date + term; the 24-month term → INVALID_FD_TERM.
TC-ACC-04	UI	US-10, ACC-03	Open the detail view of a Savings, a Checking, and a Fixed Deposit account.	Savings shows the annual interest rate and the minimum required balance; Checking shows the overdraft limit; Fixed Deposit shows the lock-in term in months and the maturity date.
TC-ACC-05	Integration	US-09, ACC-04, BR-20, BR-21	Close an ACTIVE account with balance 0.00. Attempt to close accounts with balances 250.00 and -100.00, and a FROZEN account with balance 0.00. Open the statement of the closed account and attempt a deposit into it.	The 0.00 account is closed. The 250.00 and -100.00 accounts are rejected with NON_ZERO_BALANCE; the FROZEN account is rejected with ACCOUNT_NOT_ACTIVE. The closed account keeps its statement entries and the deposit is rejected with ACCOUNT_CLOSED.
TC-ACC-06	Unit / UI	US-06, US-07, US-08, US-15, ACC-02, ACC-07, BR-23	Unit: generate 1,000 account numbers and check each for 12 numeric digits, a valid Luhn check digit, and uniqueness; close an account and confirm its number is never reissued. UI: enter transfer destinations of 11 digits, 13 digits, letters, and 12 digits with an incorrect check digit.	All generated numbers are valid and unique, and closed numbers are not reused. Each invalid entry is rejected with INVALID_ACCOUNT_NUMBER (HTTP 400) before any database query is executed.
TC-ACC-07	Integration	US-22, ACC-05, BR-20, AUD-01	The administrator freezes an ACTIVE account with an empty reason, with a 255-character reason, and with a 256-character reason; unfreezes the FROZEN account with an empty reason and then with a valid reason; and attempts to freeze a CLOSED account.	Empty and 256-character reasons are rejected and the status is unchanged. The 255-character reason is accepted. ACTIVE → FROZEN and FROZEN → ACTIVE succeed. The CLOSED account is rejected with ACCOUNT_CLOSED. Each successful action writes an audit entry containing the reason.
TC-FRZ-01	API / UI	US-22, TXN-01, TXN-02, TXN-03, BR-20	As the owner, attempt a deposit, a withdrawal, and a transfer from a FROZEN account. As Customer A, transfer 100.00 EGP to a FROZEN account of Customer B.	All four requests are rejected with ACCOUNT_FROZEN (HTTP 423 or 422); balances and ledger rows are unchanged.

Suite 5.2.2.3 Transactions, Ledger, and Concurrency

Test ID	Type	Traceability	Test Scenario / Test Data	Expected Result
TC-MON-01	Unit / API	NFR-01, BR-01, TXN-07	Submit the amounts 0, -10.00, 10.005, and "abc" as deposit, withdrawal, and transfer amounts.	Each request is rejected with INVALID_AMOUNT (HTTP 400) and the message 'Please enter a valid positive amount with up to 2 decimal places.' No balance or ledger row changes.
TC-MON-02	Unit / DB / Static	NFR-01	Unit: deposit 1,000.50 EGP, calculate the transfer fee for 1,234.55 EGP, and calculate Savings interest on 10,000.00 EGP. Database: read the stored balance column. Static: scan the Java sources and the schema for double, float, and REAL.	Domain values are BigDecimal with scale 2 and HALF_UP rounding. The stored balance is the BIGINT value 100050. No floating-point type is found.
TC-MON-03	API	BR-03	Submit a deposit request that specifies the currency USD.	The request is rejected with UNSUPPORTED_CURRENCY; every amount

				shown in the application is in EGP.
TC-DEP-01	API	US-11, TXN-01, TXN-04, BR-01, BR-02	Deposit 9.99, 10.00, 100,000.00, and 100,000.01 EGP into an ACTIVE Savings account.	9.99 and 100,000.01 are rejected with DEPOSIT_LIMIT_EXCEEDED. 10.00 and 100,000.00 succeed; each appends an immutable DEPOSIT ledger row with the correct balance_after.
TC-DEP-02	API	US-11, TXN-01, BR-04, BR-13, BR-20	Deposit 100.00 EGP into a Fixed Deposit account, a FROZEN account, a CLOSED account, and an account owned by another customer.	The requests return FD_DEPOSIT_NOT_ALLOWED, ACCOUNT_FROZEN, ACCOUNT_CLOSED, and ACCOUNT_NOT_FOUND (HTTP 404) respectively; no balance or ledger row changes.
TC-WD-01	API	US-12, TXN-02, TXN-04, BR-07	Withdraw 500.00 EGP from a Savings balance of 1,500.00 EGP.	The withdrawal succeeds; the balance becomes 1,000.00 EGP and a WITHDRAWAL ledger row with balance_after 1,000.00 is written.
TC-WD-02 (TC-F-07)	Unit / API	US-12, TXN-02, TXN-07, BR-07	Withdraw 500.01 EGP from a Savings balance of 1,500.00 EGP.	The request is rejected with MIN_BALANCE_VIOLATION (HTTP 422) and the message 'Savings account balance cannot fall below the 1,000.00 EGP minimum.' Balance and ledger are unchanged.
TC-WD-03	Unit / API	US-13, TXN-02, BR-10	Checking balance 0.00 EGP: withdraw 1,000.00 EGP, then withdraw 0.01 EGP.	The first withdrawal succeeds and the balance is -1,000.00 EGP. The second is rejected with OVERDRAFT_LIMIT_EXCEEDED.
TC-WD-04	API (Clock)	US-12, US-13, TXN-06, BR-05, BR-06, NFR-05	Account funded with 1,000,000.00 EGP; Clock at the first day of a month. Day 1: withdraw 70,000.01, then 70,000.00, then 50,000.00, then 10.00. Days 2 and 3: withdraw 120,000.00 each. Day 4: withdraw 40,000.00. Day 5: withdraw 10.00.	Day 1: 70,000.01 → TXN_LIMIT_EXCEEDED; 70,000.00 and 50,000.00 succeed; 10.00 → DAILY_LIMIT_EXCEEDED. Days 2 to 4 succeed and bring the month total to 400,000.00. Day 5: 10.00 → MONTHLY_LIMIT_EXCEEDED. Fees are excluded from the totals.
TC-FD-01	Integration (Clock)	US-17, TXN-02, BR-12, BR-13, BR-14	Fixed Deposit of 5,000.00 EGP for 12 months. Before maturity attempt a withdrawal and a deposit. After maturity and interest posting attempt a withdrawal of 1,000.00, then a full withdrawal of 5,850.00.	Withdrawal before maturity → FD_NOT_MATURE; deposit → FD_DEPOSIT_NOT_ALLOWED; partial withdrawal after maturity → FD_PARTIAL_WITHDRAWAL_NOT_ALLOWED; full withdrawal of principal plus interest succeeds and the balance becomes 0.00.
TC-TX-01	UI / API	US-15, US-16, TXN-03, TXN-04, TXN-05, TXN-09, BR-26, BR-29	Customer A (Checking balance 5,000.00 EGP) transfers 1,000.00 EGP with the description "Invoice 1042" to an ACTIVE account of Customer B. Review the confirmation screen, then confirm.	The confirmation shows the masked destination account holder name, the destination account number, the fee 1.00 EGP, and the total debit 1,001.00 EGP. After confirmation Customer A's balance is 3,999.00 EGP, Customer B's balance rises by 1,000.00 EGP, and three ledger rows share one reference: TRANSFER_OUT 1,000.00 and FEE 1.00 on A, TRANSFER_IN 1,000.00 on B, each with the correct balance_after.
TC-TX-02	UI / API	US-14, TXN-03, TXN-04, TXN-05, BR-27	Customer A transfers 500.00 EGP from Checking to A's own Savings account.	The fee is 0.00 EGP. TRANSFER_OUT and TRANSFER_IN rows are written with one reference and no FEE row. Both balances update atomically.
TC-TX-03	API	US-16, TXN-08, BR-19	Send the same transfer POST twice with the header Idempotency-Key "key-001" within 24 hours. Send a different operation with "key-001".	The transfer executes once. The second request returns the identical response payload and writes no ledger rows. The different operation is rejected with IDEMPOTENCY_CONFLICT.
TC-TX-04	Unit	US-15, BR-01, BR-26	Calculate the inter-customer fee for 100.00, 500.00, 1,000.00, 1,234.55, 1,235.00, 20,000.00, and 50,000.00 EGP.	Fees are 0.50, 0.50, 1.00, 1.23, 1.24, 20.00, and 20.00 EGP (0.1%, HALF_UP, minimum 0.50, maximum 20.00).

TC-TX-05	API	US-15, TXN-03, TXN-07, BR-05, BR-28	Transfer to the same account; to a non-existent but Luhn-valid number; from Savings 1,500.00 to another customer 499.60 (fee 0.50) and 499.50 (fee 0.50); from Checking -900.00 to another customer 99.60 (fee 0.50); 70,000.01 from a funded account.	SAME_ACCOUNT_TRANSFER (HTTP 400); ACCOUNT_NOT_FOUND (HTTP 404); 499.60 → MIN_BALANCE_VIOLATION (balance would be 999.90); 499.50 succeeds and leaves 1,000.00; Checking → OVERDRAFT_LIMIT_EXCEEDED (balance would be -1,000.10); 70,000.01 → TXN_LIMIT_EXCEEDED. Rejected requests leave no partial change.
TC-TX-06	API	US-16, TXN-09, BR-26, BR-27	Call the transfer-fee quote endpoint for an inter-customer transfer of 1,000.00 EGP, for an own-account transfer, and for an invalid destination number. Compare balances and ledger rows before and after.	The quote returns fee 1.00 and total debit 1,001.00 EGP; the own-account quote returns fee 0.00; the invalid number returns INVALID_ACCOUNT_NUMBER. No balance changes and no ledger row is written.
TC-TX-07	API	TXN-03	Transfer with descriptions of 100 and 101 characters.	The 100-character description is accepted; the 101-character description is rejected with a validation message.
TC-LED-01	Integration / DB	TXN-04, BR-16, BR-17, BR-18, NFR-04	Perform a deposit, a withdrawal, an inter-customer transfer, and an own-account transfer, then inspect the ledger rows. Review database permissions and repository code for UPDATE and DELETE paths on ledger rows and attempt an update and a delete through the application layer.	Every row stores type, amount, balance_after, counterparty account number, description, timestamp, and a unique reference of the form TXN-YYYYMMDD-XXXXXX shared by all legs of one operation. The latest balance_after equals the account balance. No update or delete path exists and the attempts are refused (LEDGER_IMMUTABLE_VIOLATION).
TC-DB-01	Integration / DB	NFR-03, TXN-05, BR-29	Inject an exception after the TRANSFER_OUT row is written during an inter-customer transfer.	The whole database transaction rolls back: both balances are unchanged and no TRANSFER_OUT, TRANSFER_IN, or FEE row remains. The failure is reported as TRANSFER_ATOMICITY_FAILURE.
TC-C-01	Concurrency	NFR-03, TXN-06, BR-06, BR-07	Savings account with balance 1,500.00 EGP. Fire one withdrawal of 500.00 EGP and one transfer of 500.00 EGP simultaneously from separate threads.	Exactly one request succeeds; the other fails with INSUFFICIENT_FUNDS or MIN_BALANCE_VIOLATION. The final balance is 1,000.00 EGP and equals the exact ledger sum.
TC-C-02	Concurrency	NFR-03, TXN-06, BR-06	Account with ample balance and 50,000.00 EGP already withdrawn today. Fire two simultaneous withdrawals of 70,000.00 EGP.	Exactly one succeeds; the other fails with DAILY_LIMIT_EXCEEDED. The daily total is 120,000.00 EGP and no duplicate ledger row exists.
TC-C-03	Concurrency	NFR-03, TXN-05, TXN-06	Fire 20 simultaneous deposits of 10.00 EGP into one account.	All 20 deposits succeed, the balance rises by exactly 200.00 EGP, 20 DEPOSIT rows exist, and no SQLITE_BUSY error is returned.

Suite 5.2.2.4 Statements

Test ID	Type	Traceability	Test Scenario / Test Data	Expected Result
TC-STMT-01	API / UI	US-19, STM-01, BR-17	Account with 25 ledger rows: open the statement, open page 3, request 100 rows per page, and request 101 rows per page.	Rows are ordered newest first and show balance_after. The default page shows 10 rows and page 3 shows 5. A page never holds more than 100 rows, including the request for 101.
TC-STMT-02	API / UI	US-19, STM-02	Filter by start date, by end date, by both, and by each type DEPOSIT, WITHDRAWAL, TRANSFER_IN, TRANSFER_OUT, FEE, and INTEREST.	Only matching rows are returned, in newest-first order, and pagination applies to the filtered result.
TC-STMT-03	API / UI	US-20, STM-03	Export a filtered statement that contains a ledger description "=1+1".	The UTF-8 CSV file has standard headers and contains only the filtered rows. The description is exported as text and is not

				evaluated as a formula when opened in Excel.

Suite 5.2.2.5 Administration, Scheduled Jobs, and Audit Logging

Test ID	Type	Traceability	Test Scenario / Test Data	Expected Result
TC-ADM-01	Integration	US-21, US-25, ADM-01, ADM-07	Compare the admin dashboard with SQL aggregates, including a CLOSED account that holds a balance; check whether the administrator holds any bank account.	Reserves exclude CLOSED accounts. Customer count, account counts by type and status, today's transactions, and today's fees equal the database values. The administrator holds no account.
TC-ADM-02	API / UI	US-21, ADM-02, BR-25	Search customers by " ali ", "AL", "a", " a ", an empty string, and " ".	" ali " and "AL" return every customer whose name contains the text, ignoring case and surrounding spaces. The remaining queries are rejected with INVALID_SEARCH_QUERY.
TC-ADM-03	API / UI	US-21, ADM-03, ADM-04	Filter accounts by 12-digit number, type, status, minimum balance, and maximum balance. Run the richest-customer report with two customers tied for the highest total.	Each filter returns exactly the matching accounts. The report lists both tied customers and counts only non-closed accounts.
TC-ADM-04	API / UI	US-24, ADM-05, AUD-02	Filter the audit log by date range, by actor, and by action type.	Entries are ordered newest first and contain timestamp, actor, action code, target, outcome, reason, and client IP. No password, hash, or session token appears.
TC-ADM-05	Integration	US-23, ADM-06, JOB-01, AUD-01	The administrator triggers the monthly interest job twice in the same calendar month.	The first run credits interest to every qualifying account; the second run credits nothing. Each trigger writes an audit entry.
TC-JOB-01	Unit / Integration (Clock)	US-18, JOB-01, BR-08, NFR-05	ACTIVE Savings accounts of 10,000.00 and 1,000.00 EGP, a FROZEN Savings account of 5,000.00 EGP, and a CLOSED Savings account. Run the job twice in one month, advance the Clock to the next month, and run it again.	INTEREST rows of 141.67 and 14.17 EGP are posted (balance × 0.17 / 12, HALF_UP) with the correct balance_after; none for the FROZEN and CLOSED accounts. The second run posts nothing (INTEREST_ALREADY_POSTED). The next month's run posts interest again.
TC-JOB-02	Integration (Clock)	US-17, JOB-02, BR-12, BR-15	Fixed Deposit A: 5,000.00 EGP, 12 months, 17.00%. Fixed Deposit B: 5,000.00 EGP, 36 months, 17.75%. Run the maturity job before maturity, on the maturity date, and a second time.	No interest is posted before maturity. On maturity an INTEREST row of 850.00 EGP (balance 5,850.00) and one of 2,662.50 EGP (balance 7,662.50) are posted once. The second run posts nothing (FD_INTEREST_ALREADY_CREDITED) and each deposit is marked matured for full withdrawal.
TC-AUD-01	Integration	US-22, US-24, AUD-01, AUD-02, SEC-11	Perform one of each audited event: register, login success, login failure, lockout, account open, close, freeze, and unfreeze, deposit, withdrawal, successful transfer, failed transfer, manual job trigger, and a denied request for another customer's account.	Each event produces an audit entry with timestamp, actor (email or SYSTEM), action code, target, outcome SUCCESS or FAILURE with the error code, reason or details, and client IP. No password, hash, or session token is logged.

Suite 5.2.2.6 Security

Test ID	Type	Traceability	Test Scenario / Test Data	Expected Result
TC-SEC-01	API / UI	US-04, AUTH-04, SEC-01, SEC-02	Customer A requests Customer B's account detail, statement, and a transaction, and attempts a deposit, a withdrawal, and a transfer from that account, through the Web UI and the	Every request returns HTTP 404 ACCOUNT_NOT_FOUND with the same message and response structure as for the non-existent account. No data of Customer B is disclosed and HTTP 403 is never

			REST API. Repeat with a non-existent but Luhn-valid account number.	returned.
TC-SEC-02	API	US-04, US-25, ADM-07, AUTH-03, SEC-01	The administrator submits a deposit, a withdrawal, a transfer, and an account-opening request.	The deposit, withdrawal, and transfer return HTTP 403 Forbidden; the account-opening request is rejected; no financial data changes.
TC-SEC-03	Security	US-04, SEC-01, AUTH-03, AUTH-04	Send an unauthenticated request to a customer page and to an /api/ endpoint. As Customer A request an admin page and an admin API endpoint by direct URL. Request a route that has no explicit authorization rule.	The unauthenticated web request is redirected to the login page and the API request is rejected. Customer A is denied the admin page and endpoint (HTTP 403). The route without a rule is denied by default.
TC-SEC-04	Security	SEC-03, AUTH-05	Register two users with the same password and read their stored password values and the BCrypt cost factor. Record the session ID before and after login.	The stored values are different salted BCrypt hashes with a cost factor of at least 10 and no plaintext. The session ID changes at login (session fixation protection).
TC-SEC-05	Security	SEC-04	Enter ' OR '1'='1 in the login, search, and filter fields. Enter <script>alert(1)</script> in the full name and the transfer description. Review templates and repository code.	No injection occurs. The script text is displayed as escaped text. Code review finds no th:utext and no string-concatenated query, and Jakarta Bean Validation rejects invalid DTOs.
TC-SEC-06	Security	SEC-05	Submit state-changing web form POSTs (transfer, profile update, freeze) without a CSRF token, with a modified token, and with a valid token. Call a state-changing endpoint under /api/ with HTTP Basic credentials and no CSRF token.	Requests without a token or with a modified token are rejected; the request with a valid token is accepted. The /api/ request is not blocked by CSRF protection.
TC-SEC-07	Security	SEC-06	Inspect the session cookie attributes over HTTP and over HTTPS.	The cookie has HttpOnly=true and SameSite=Lax, and has Secure=true over HTTPS.
TC-SEC-08	Security	SEC-07	Inspect the response headers of an authenticated page.	The response contains X-Content-Type-Options: nosniff, X-Frame-Options: DENY, Cache-Control: no-store, and a restrictive Content-Security-Policy that disallows inline scripts.
TC-SEC-09	Security / Static	SEC-08, US-25, ADM-07	Search the working tree and Git history for secrets and .db or .sqlite files and check .gitignore. Open Swagger UI outside the dev profile as an anonymous user, a customer, and an administrator. Trigger an unhandled error. Inspect API responses, DTOs, views, and log files for password hashes.	No secret or database file is committed. Swagger UI is disabled or restricted to ADMIN. The custom error page shows no stack trace. No password hash appears in any DTO, view, API response, or log file.
TC-SEC-10	Static	SEC-10	Run OWASP Dependency-Check or GitHub Dependabot before final delivery.	The scan report is archived and its findings are triaged. The final report documents the end of free commercial security updates for Spring Boot 3.5 in June 2026 and the upgrade path to Spring Boot 4.1.
TC-LOG-01	Integration	NFR-11, SEC-11	Run the complete test suite with log capture and inspect the application logs.	Logs use the severity levels INFO, WARN, and ERROR. No plaintext password, password hash, or session cookie appears, and account numbers show only the last 4 digits.

Suite 5.2.2.7 Non-Functional Verification

Test ID	Type	Traceability	Test Scenario / Test Data	Expected Result
TC-PERF-01	Performance	NFR-02	Run the Postman collection against all REST endpoints on a standard developer	REST endpoints respond in under 500 ms at the 95th percentile (KPI-05) and server-

			workstation with seed data. Record the load time of each server-rendered page during the Selenium run.	rendered pages load in under 2.0 seconds.
TC-NFR-05	Unit / Static / UI	NFR-05	Review the code for time access outside the injected Clock. Check that every interactive HTML element has a permanent unique ID. Start the application under a profile other than dev or test and call the seed and database-reset hooks.	Time is obtained only from the injected Clock bean. Every interactive element has a unique, permanent ID. Seed data and reset hooks are inactive outside dev and test.
TC-UI-01	UI / Manual	NFR-06	Submit forms with invalid values, read the success and error banners, and render the application at 1366 px and 375 px viewport widths.	Field-level messages appear next to the invalid inputs, banners use fixed DOM IDs, and all controls remain visible and operable at both widths.
TC-UI-02	UI / Manual	NFR-07	Run the Selenium suite on the latest Chrome. Execute a smoke checklist (login, open account, deposit, transfer, statement, admin dashboard) on Firefox and Edge.	The Chrome suite passes and every smoke check passes on Firefox and Edge.
TC-UI-03	Manual	NFR-12	Check that every form input is bound to a label with for=; operate every form with the Tab key only; measure text and background contrast.	All inputs are label-bound, all forms are keyboard-operable, and all colour combinations meet WCAG AA contrast.
TC-NFR-08	Static	NFR-08	Run SonarLint and SpotBugs, review the package structure and the Thymeleaf templates, and review the pull-request checklist of merged changes.	The Controller → Service → Domain → Repository layering holds, controllers and templates contain no business calculation, and every change has a peer-reviewed pull request.
TC-NFR-09	Manual	NFR-09	Clone the repository on team laptops running Windows, Linux, and macOS with JDK 17+ and run mvn spring-boot:run (or ./mvnw spring-boot:run).	The application builds and starts on each system without installing an external database server.
TC-NFR-10	Manual	NFR-10	Open Swagger UI under the dev profile. Follow the README on a fresh clone, including the PowerShell commands.	Swagger UI is generated from the controller annotations and lists the endpoints. The README documents setup commands, active profiles, and demo credentials, and a new team member completes the setup with it.

5.2.3 Bidirectional Requirement Traceability Matrix (RTM)

User Story ID	Verifying Test Case(s)	User Story ID	Verifying Test Case(s)
US-01 (Registration)	TC-REG-01, TC-REG-02	**US-02 (Login & Lockout)**	TC-AUTH-01, TC-AUTH-02, TC-AUTH-03
US-03 (Logout & Idle Expiry)	TC-AUTH-02, TC-SESSION-01	**US-04 (RBAC & IDOR 404)**	TC-SEC-01, TC-SEC-02, TC-SEC-03
US-05 (Customer Profile)	TC-CUS-01	**US-06 (Open Savings Account)**	TC-ACC-01, TC-ACC-02, TC-ACC-03, TC-ACC-06
US-07 (Open Checking Account)	TC-ACC-02, TC-ACC-03, TC-ACC-06	**US-08 (Open Fixed Deposit)**	TC-ACC-02, TC-ACC-03, TC-ACC-06
US-09 (Close Zero-Balance Acc)	TC-ACC-05	**US-10 (Customer Dashboard)**	TC-CUS-02, TC-ACC-04
US-11 (Cash Deposit)	TC-DEP-01, TC-DEP-02	**US-12 (Savings Withdrawal)**	TC-WD-01, TC-WD-02 (TC-F-07), TC-WD-04, TC-C-01
US-13 (Checking Withdrawal)	TC-WD-03, TC-WD-04	**US-14 (Own-Account Transfer)**	TC-TX-02
US-15 (Inter-Customer	TC-ACC-06, TC-TX-01, TC-TX-04, TC-TX-05	**US-16 (Fee Quote &**	TC-TX-01, TC-TX-03, TC-TX-06

Transfer)		Idempotency)	
US-17 (FD Maturity & Withdraw)	TC-FD-01, TC-JOB-02	**US-18 (Monthly Savings Interest)**	TC-JOB-01
US-19 (Paginated Statements)	TC-STMT-01, TC-STMT-02	**US-20 (Sanitized CSV Export)**	TC-STMT-03
US-21 (Admin Dashboard & Search)	TC-ADM-01, TC-ADM-02, TC-ADM-03	**US-22 (Admin Freeze/Unfreeze)**	TC-ACC-07, TC-FRZ-01, TC-AUD-01
US-23 (Admin Manual Interest Job)	TC-ADM-05	**US-24 (Immutable Audit Logs)**	TC-ADM-04, TC-AUD-01
US-25 (Admin Least-Privilege)	TC-ADM-01, TC-SEC-02, TC-SEC-09		

Functional Requirements Traceability

ID	Test Case(s)	ID	Test Case(s)
AUTH-01	TC-REG-01	**AUTH-02**	TC-AUTH-02, TC-AUTH-03
AUTH-03	TC-AUTH-02, TC-AUTH-03, TC-SEC-02, TC-SEC-03	**AUTH-04**	TC-SEC-01, TC-SEC-03
AUTH-05	TC-REG-02, TC-SEC-04	**AUTH-06**	TC-AUTH-01
AUTH-07	TC-SESSION-01	**AUTH-08**	TC-AUTH-04
CUS-01	TC-CUS-01	**CUS-02**	TC-REG-01, TC-REG-02, TC-CUS-01
CUS-03	TC-CUS-02	**ACC-01**	TC-ACC-01, TC-ACC-03
ACC-02	TC-ACC-01, TC-ACC-06	**ACC-03**	TC-ACC-04
ACC-04	TC-ACC-05	**ACC-05**	TC-ACC-07
ACC-06	TC-ACC-02	**ACC-07**	TC-ACC-06
TXN-01	TC-FRZ-01, TC-DEP-01, TC-DEP-02	**TXN-02**	TC-FRZ-01, TC-WD-01, TC-WD-02 (TC-F-07), TC-WD-03, TC-FD-01
TXN-03	TC-FRZ-01, TC-TX-01, TC-TX-02, TC-TX-05, TC-TX-07	**TXN-04**	TC-DEP-01, TC-WD-01, TC-TX-01, TC-TX-02, TC-LED-01
TXN-05	TC-TX-01, TC-TX-02, TC-DB-01, TC-C-03	**TXN-06**	TC-WD-04, TC-C-01, TC-C-02, TC-C-03
TXN-07	TC-MON-01, TC-WD-02 (TC-F-07), TC-TX-05	**TXN-08**	TC-TX-03
TXN-09	TC-TX-01, TC-TX-06	**STM-01**	TC-STMT-01
STM-02	TC-STMT-02	**STM-03**	TC-STMT-03
ADM-01	TC-ADM-01	**ADM-02**	TC-ADM-02
ADM-03	TC-ADM-03	**ADM-04**	TC-ADM-03
ADM-05	TC-ADM-04	**ADM-06**	TC-ADM-05
ADM-07	TC-ADM-01, TC-SEC-02, TC-SEC-09	**JOB-01**	TC-ADM-05, TC-JOB-01
JOB-02	TC-JOB-02	**AUD-01**	TC-REG-01, TC-AUTH-01, TC-ACC-07, TC-ADM-05, TC-AUD-01
AUD-02	TC-AUTH-01, TC-ADM-04, TC-AUD-01		

Security Requirements Traceability

ID	Test Case(s)	ID	Test Case(s)

SEC-01	TC-SEC-01, TC-SEC-02, TC-SEC-03	**SEC-02**	TC-SEC-01
SEC-03	TC-AUTH-02, TC-AUTH-01, TC-SEC-04	**SEC-04**	TC-SEC-05
SEC-05	TC-SEC-06	**SEC-06**	TC-SESSION-01, TC-SEC-07
SEC-07	TC-SEC-08	**SEC-08**	TC-AUTH-04, TC-SEC-09
SEC-09	TC-AUTH-01	**SEC-10**	TC-SEC-10
SEC-11	TC-AUD-01, TC-LOG-01		

Business Rules Traceability

ID	Test Case(s)	ID	Test Case(s)
BR-01	TC-ACC-03, TC-MON-01, TC-DEP-01, TC-TX-04	**BR-02**	TC-DEP-01
BR-03	TC-MON-03	**BR-04**	TC-DEP-02
BR-05	TC-WD-04, TC-TX-05	**BR-06**	TC-WD-04, TC-C-01, TC-C-02
BR-07	TC-ACC-01, TC-ACC-03, TC-WD-01, TC-WD-02 (TC-F-07), TC-C-01	**BR-08**	TC-JOB-01
BR-09	TC-ACC-03	**BR-10**	TC-WD-03
BR-11	TC-ACC-03	**BR-12**	TC-ACC-03, TC-FD-01, TC-JOB-02
BR-13	TC-DEP-02, TC-FD-01	**BR-14**	TC-FD-01
BR-15	TC-JOB-02	**BR-16**	TC-LED-01
BR-17	TC-LED-01, TC-STMT-01	**BR-18**	TC-LED-01
BR-19	TC-TX-03	**BR-20**	TC-ACC-05, TC-ACC-07, TC-FRZ-01, TC-DEP-02
BR-21	TC-ACC-05	**BR-22**	TC-ACC-02
BR-23	TC-ACC-06	**BR-24**	TC-REG-01, TC-AUTH-01
BR-25	TC-ADM-02	**BR-26**	TC-TX-01, TC-TX-04, TC-TX-06
BR-27	TC-TX-02, TC-TX-06	**BR-28**	TC-TX-05
BR-29	TC-TX-01, TC-DB-01		

Non-Functional Requirements Traceability

ID	Test Case(s)	ID	Test Case(s)
NFR-01	TC-MON-01, TC-MON-02	**NFR-02**	TC-PERF-01
NFR-03	TC-DB-01, TC-C-01, TC-C-02, TC-C-03	**NFR-04**	TC-LED-01
NFR-05	TC-AUTH-01, TC-SESSION-01, TC-WD-04, TC-JOB-01, TC-NFR-05	**NFR-06**	TC-UI-01
NFR-07	TC-UI-02	**NFR-08**	TC-NFR-08
NFR-09	TC-NFR-09	**NFR-10**	TC-NFR-10
NFR-11	TC-LOG-01	**NFR-12**	TC-UI-03

5.3 User Acceptance Testing (UAT Scenarios S1–S14 & Sign-Off)

The 14 End-to-End UAT scenarios validate all 25 User Stories (US-01 to US-25) across customer and administrator workflows using deterministic seed accounts (Customer A, Customer B, Customer C, Customer E, and Administrator):

Scenario & User Stories	Preconditions & Test Data	Execution Steps	Expected Acceptance Results
Scenario 1: Customer Registration (US-01)	The registration page is reachable and the email "mona.hassan@example.com" is not registered.	1. Open the registration page. 2. Enter full name "Mona Hassan", email "Mona.Hassan@example.com", phone "+201001234567", and password "Secure1Pass", then submit. 3. Log out, then log in with the same email and password. 4. Open the registration page again, enter email "mona.hassan@example.com" with a valid name and password, and submit. 5. Enter a new email with the password "abc" and submit.	• Step 2 creates the login credential and the customer profile together; the login in step 3 succeeds (AUTH-01). • Step 4 is rejected with DUPLICATE_EMAIL because the email check ignores letter case (BR-24). • Step 5 shows a field-level message stating the password rules (8 to 64 characters with at least one uppercase letter, one lowercase letter, and one digit) and creates no account (AUTH-05, CUS-02).
Scenario 2: Open a Savings Account (US-06, US-10)	Customer A holds fewer than five non-closed accounts. Customer E holds exactly five non-closed accounts.	1. Log in as Customer A, open the account-creation page, select Savings Account, enter an opening deposit of 999.99 EGP, and submit. 2. Enter an opening deposit of 1,000.00 EGP and submit. 3. Return to the dashboard. 4. Log in as Customer E, open the account-creation page, select Savings Account, enter 1,000.00 EGP, and submit.	• Step 1 is rejected with MIN_BALANCE_VIOLATION and no account is created, because the Savings minimum opening deposit is 1,000.00 EGP (BR-07). • Step 2 creates the account with an opening balance of 1,000.00 EGP and a unique 12-digit account number (ACC-02). • The dashboard shows the new account with type Savings, its account number, status ACTIVE, and balance 1,000.00 EGP, and the total balance includes it (US-10, CUS-03). • Step 4 is rejected with MAX_ACCOUNTS_EXCEEDED (ACC-06, BR-22).
Scenario 3: Transfer Money to Another Customer (US-15, US-16)	Customer A has a Checking account with balance 5,000.00 EGP. Customer B has an ACTIVE account whose 12-digit number is known.	1. Log in as Customer A and open the transfer page. 2. Select the Checking account as source, enter Customer B's account number, the amount 1,000.00 EGP, and the description "Invoice 1042". 3. Continue to the confirmation screen and review it, then confirm the transfer. 4. Open the statement of Customer A's Checking account, then log in as Customer B and open the statement of the destination account. 5. As Customer A, repeat the transfer with the amount 6,100.00 EGP. 6. As an API user, request the fee quote for 1,000.00 EGP to the same destination and then compare balances and statements.	• The confirmation shows the masked destination account holder name, the destination account number, the fee 1.00 EGP (0.1% with a minimum of 0.50 and a maximum of 20.00 EGP), and the total debit 1,001.00 EGP before execution (BR-26, TXN-09). • After confirmation Customer A's balance is 3,999.00 EGP and the destination balance rises by 1,000.00 EGP atomically (TXN-05). • The ledger shows TRANSFER_OUT 1,000.00 and FEE 1.00 on Customer A's account and TRANSFER_IN 1,000.00 on Customer B's account, all sharing one reference (US-15, BR-29). • Step 5 is rejected with OVERDRAFT_LIMIT_EXCEEDED; balances and ledger rows are unchanged (BR-10, TXN-05). • The quote in step 6 returns fee 1.00 EGP and total debit 1,001.00 EGP and changes no balance and writes no ledger row (US-16, TXN-09).
Scenario 4: View Account Statement & Export CSV (US-19, US-20)	Customer A owns an account with at least 25 ledger entries (deposits, withdrawals, transfers, a fee, and interest) posted on at least two different dates.	1. Open Statements and select the account. 2. Review the first page, then open page 3. 3. Set the page size to 100 rows. 4. Filter by a start date and an end date that cover part of the history. 5. Filter by the transaction type FEE. 6. Export the filtered statement to CSV and open the file in Excel.	• Transactions are ordered newest first and show the running balance after each entry (STM-01, BR-17). • The first page shows 10 rows, page 3 shows the remaining 5, and no page shows more than 100 rows (STM-01). • The date filter returns only entries inside the range and the type filter returns only FEE entries (STM-02). • The CSV file is UTF-8, has standard headers, contains only the filtered rows, opens correctly in Excel, and shows text beginning with "=" as text (STM-03).
Scenario 5: Freeze and	Customer A owns an ACTIVE	1. Log in as the administrator, search for the	• Step 2 is refused because a reason is

Unfreeze an Account (US-22, US-24)	Savings account. An administrator account exists.	customer, and open Customer A's Savings account. 2. Choose Freeze and submit with an empty reason. 3. Enter the reason "Suspicious activity reported" and submit. 4. Log out, log in as Customer A, and attempt a deposit of 100.00 EGP, a withdrawal of 100.00 EGP, and a transfer of 100.00 EGP from the frozen account. 5. Log in as the administrator and open the audit log filtered by the action type for account status changes. 6. Choose Unfreeze and submit with an empty reason, then with the reason "Verified by customer". 7. Log in as Customer A and deposit 100.00 EGP.	mandatory and the status stays ACTIVE (ACC-05). • Step 3 changes the status from ACTIVE to FROZEN (BR-20). • Each operation in step 4 is rejected with ACCOUNT_FROZEN (BR-20). • The audit log shows the freeze with actor, timestamp, target account, reason, result, and client IP (AUD-01, AUD-02). • Step 6 refuses the empty reason, then changes the status to ACTIVE and writes an audit entry (ACC-05). • The deposit in step 7 succeeds.
Scenario 6: Login, Logout, Lockout, and Inactivity Timeout (US-02, US-03)	Customer C exists. The test environment's injected Clock advances time for the 15-minute checks (NFR-05).	1. Log in as Customer C with the correct password. 2. Log out, then press the browser Back button. 3. Enter a wrong password for Customer C five times in a row. 4. Enter the correct password for Customer C. 5. Advance the Clock by 15 minutes after the fifth failure and enter the correct password. 6. After logging in, stay idle for 15 minutes and then click any link.	• Step 1 opens the customer dashboard and renews the session ID (US-02). • Step 2 shows the login page and no protected content (US-02). • Every failed attempt shows only 'Invalid email or password' (US-02). • Step 4 is refused with the same generic message and a lockout entry is written to the audit log (AUTH-06, SEC-09, AUD-01). • Step 5 logs in successfully (AUTH-06). • Step 6 invalidates the session and redirects to the login page (AUTH-07, SEC-06).
Scenario 7: Profile and Dashboard (US-05, US-10)	Customer A holds two ACTIVE accounts, one FROZEN account, and one CLOSED account.	1. Open the profile page. 2. Change the full name to "Mona Hassan-Ali" and the phone to "01001234567" and save. 3. Enter the name "M1" and the phone "12345" and save. 4. Try to edit the email address. 5. Open the dashboard.	• Step 2 persists the new values immediately (CUS-01). • Step 3 shows field-level error messages and saves nothing (CUS-02). • The email is displayed read-only and cannot be modified (CUS-01). • The dashboard lists every account with type, 12-digit number, status (ACTIVE, FROZEN, CLOSED), and balance, and the total equals the sum of the non-closed accounts (CUS-03).
Scenario 8: Open Checking and Fixed Deposit Accounts (US-07, US-08, US-10)	Customer A holds fewer than five non-closed accounts.	1. Open a Checking account with an opening deposit of 0.00 EGP. 2. Open a Fixed Deposit account with 4,999.99 EGP and a 12-month term. 3. Open a Fixed Deposit account with 5,000.00 EGP and a 36-month term. 4. Open the detail view of the Savings, Checking, and Fixed Deposit accounts.	• Step 1 creates the Checking account with balance 0.00 EGP (BR-09). • Step 2 is rejected with MIN_OPENING_DEPOSIT_VIOLATION (BR-11). • Step 3 creates the Fixed Deposit with rate 17.75%, term 36 months, and a maturity date equal to the opening date plus 36 months (BR-12). • The detail views show the annual rate and minimum balance (Savings), the overdraft limit (Checking), and the lock-in term and maturity date (Fixed Deposit) (ACC-03).
Scenario 9: Deposit and Withdrawal (US-11, US-12, US-13)	Customer A owns a Savings account (balance 1,500.00 EGP), a Checking account (balance 0.00 EGP), a Fixed Deposit account, and a second Savings account with balance 500,000.00 EGP.	1. Deposit 9.99 EGP, then 100.00 EGP, into the first Savings account. 2. Deposit 100,000.01 EGP into the second Savings account. 3. Deposit 100.00 EGP into the Fixed Deposit account. 4. Withdraw 600.00 EGP from the first Savings account, then withdraw 0.01 EGP. 5. Withdraw 1,000.00 EGP from the Checking account, then withdraw 0.01 EGP. 6. Withdraw 70,000.01 EGP from the second Savings account.	• 9.99 is rejected with DEPOSIT_LIMIT_EXCEEDED; 100.00 succeeds and appends a DEPOSIT ledger row (BR-02, TXN-01). • 100,000.01 is rejected with DEPOSIT_LIMIT_EXCEEDED (BR-02). • The Fixed Deposit deposit is rejected with FD_DEPOSIT_NOT_ALLOWED (BR-13). • The 600.00 withdrawal succeeds and leaves 1,000.00 EGP; the next 0.01 withdrawal is rejected with MIN_BALANCE_VIOLATION (BR-07). • The Checking balance reaches -1,000.00 EGP and the next 0.01 withdrawal is rejected with OVERDRAFT_LIMIT_EXCEEDED (BR-10).

			• The 70,000.01 withdrawal is rejected with TXN_LIMIT_EXCEEDED (BR-05).
Scenario 10: Own-Account Transfer and Safe Retry (US-14, US-16)	Customer A owns a Checking account (balance 2,000.00 EGP) and a Savings account. Customer B has an ACTIVE account.	1. Transfer 500.00 EGP from Customer A's Checking account to Customer A's Savings account. 2. Open the statements of both accounts. 3. With an API client, send a transfer to Customer B twice with the same Idempotency-Key "key-uat-10".	• The fee is 0.00 EGP and both balances update atomically (BR-27). • Each statement shows one row (TRANSFER_OUT and TRANSFER_IN) with the same reference and no FEE row (US-14). • The financial operation executes once, the second response is identical to the first, and Customer A is debited only once (US-16, TXN-08, BR-19).
Scenario 11: Close an Account (US-09)	Customer A owns ACTIVE accounts with balances 0.00 EGP, 250.00 EGP, and -100.00 EGP (Checking overdraft).	1. Close the account with balance 0.00 EGP. 2. Attempt to close the account with balance 250.00 EGP. 3. Attempt to close the account with balance -100.00 EGP. 4. Open the statement of the closed account and attempt a deposit into it. 5. Open the dashboard.	• Step 1 closes the account (BR-21). • Steps 2 and 3 are rejected with NON_ZERO_BALANCE (BR-21). • The closed account keeps its statement entries and rejects the deposit with ACCOUNT_CLOSED (ACC-04, BR-20). • The closed account is excluded from the total balance and from the five-account limit (CUS-03, BR-22).
Scenario 12: Fixed Deposit Maturity and Monthly Savings Interest (US-17, US-18, US-23)	Customer A owns an ACTIVE Savings account with balance 10,000.00 EGP, a Fixed Deposit of 5,000.00 EGP for 12 months whose maturity date has been reached through the Clock, and a second Fixed Deposit that has not matured.	1. Attempt a withdrawal from the Fixed Deposit that has not matured. 2. As the administrator, trigger the monthly interest job. 3. Trigger the monthly interest job a second time in the same month. 4. As Customer A, open the Savings statement. 5. Run the Fixed Deposit maturity processing and open the matured Fixed Deposit's statement. 6. Attempt a partial withdrawal of 1,000.00 EGP, then withdraw the full balance.	• Step 1 is rejected with FD_NOT_MATURE (BR-14). • The Savings statement shows one INTEREST entry of 141.67 EGP (10,000.00 × 17% / 12, rounded HALF_UP) and the second trigger credits nothing; both triggers appear in the audit log (JOB-01, BR-08, ADM-06, AUD-01). • The matured Fixed Deposit shows one INTEREST entry of 850.00 EGP and balance 5,850.00 EGP (JOB-02, BR-15). • The partial withdrawal is rejected with FD_PARTIAL_WITHDRAWAL_NOT_ALLOWED and the full withdrawal of 5,850.00 EGP succeeds (BR-14).
Scenario 13: Administrator Oversight (US-21, US-24, US-25)	An administrator account exists; the database holds customers, accounts of all types, a CLOSED account with a recorded balance, and two customers with equal highest totals.	1. Log in as the administrator and open the dashboard. 2. Search customers by the name " ali ", then by "a". 3. Search accounts by type SAVINGS with minimum balance 1,000.00 EGP and maximum balance 50,000.00 EGP. 4. Open the richest-customer report. 5. Open the audit log and filter by a date range, a user, and an action type.	• The dashboard shows total reserves (excluding CLOSED accounts), customer count, account counts by type and status, today's transactions, and today's fees, equal to the database aggregates (ADM-01). • The trimmed, case-insensitive search returns all matching customers; the single-character search is rejected with INVALID_SEARCH_QUERY (ADM-02, BR-25). • Only Savings accounts inside the balance range are listed (ADM-03). • The report lists both tied customers (ADM-04). • Audit entries show actor, timestamp, target, result, and client IP, and never show passwords or session tokens (ADM-05, AUD-02). The administrator has no personal bank accounts and no deposit, withdrawal, or transfer function (ADM-07).
Scenario 14: Access Protection: IDOR 404 & Admin Restrictions (US-04, US-25)	Customer A and Customer B each own an account; an administrator account exists.	1. As Customer A, open Customer B's account by its ID in the browser and by its number through the REST API. 2. As Customer A, request an account number that does not exist but has a valid check digit. 3. As the administrator, attempt a deposit, a withdrawal, and a transfer. 4. As the administrator, inspect the customer views and API responses for password values.	• Step 1 returns HTTP 404 ACCOUNT_NOT_FOUND (SEC-02). • Step 2 returns the same HTTP 404 response as step 1, so account existence is not revealed (US-04). • Step 3 returns HTTP 403 Forbidden for every request and changes no data (ADM-07, AUTH-03). • No password or password hash appears in any view or response (SEC-08).

5.3.1 User-Story-to-UAT Coverage Matrix (US-01 to US-25)

User Story ID	UAT Scenario(s)	User Story ID	UAT Scenario(s)
US-01 (Registration)	S1	**US-02 (Login & Lockout)**	S6
US-03 (Logout & Idle Expiry)	S6	**US-04 (RBAC & IDOR 404)**	S14
US-05 (Customer Profile)	S7	**US-06 (Open Savings Account)**	S2
US-07 (Open Checking Account)	S8	**US-08 (Open Fixed Deposit)**	S8
US-09 (Close Zero-Balance Acc)	S11	**US-10 (Customer Dashboard)**	S2, S7, S8
US-11 (Cash Deposit)	S9	**US-12 (Savings Withdrawal)**	S9
US-13 (Checking Withdrawal)	S9	**US-14 (Own-Account Transfer)**	S10
US-15 (Inter-Customer Transfer)	S3	**US-16 (Fee Quote & Idempotency)**	S3, S10
US-17 (FD Maturity & Withdraw)	S12	**US-18 (Monthly Savings Interest)**	S12
US-19 (Paginated Statements)	S4	**US-20 (Sanitized CSV Export)**	S4
US-21 (Admin Dashboard & Search)	S13	**US-22 (Admin Freeze/Unfreeze)**	S5
US-23 (Admin Manual Interest Job)	S12	**US-24 (Immutable Audit Logs)**	S5, S13
US-25 (Admin Least-Privilege)	S13, S14		